

通常必须相互鉴别。此处，鉴别应当在报文和数据交换的基础上，作为某鉴别协议（authentication protocol）的一部分独立完成。鉴别协议通常在两个通信实体运行其他协议（例如，可靠数据传输协议、路由选择信息交换协议或电子邮件协议）之前运行。鉴别协议首先建立相互满意的各方的标识；仅当鉴别完成之后，各方才继续下面的工作。

同第3章中我们阐释可靠数据传输协议（rdt）的情况类似，我们发现阐释各种版本的鉴别协议——我们将称为 ap（authentication protocol）——是有启发的，并随着我们学习的深入指出各个版本的漏洞。（如果你喜欢这种逐步式的设计演化，你也许喜欢看 [Bryant 1988]，这本书虚构了开放网络鉴别系统的设计者间的故事，以及他们对许多相关奇妙问题的发现。）

我们假设 Alice 要向 Bob 鉴别她自己的身份。

8.4.1 鉴别协议 ap1.0

也许我们能够想象出的最简单的鉴别协议就是：Alice 直接发送一个报文给 Bob，说她就是 Alice。这个协议如图 8-15 所示。这个协议的缺陷是明显的，即 Bob 无法判断发送报文“我是 Alice”的人确实就是 Alice。例如，Trudy（入侵者）也可以发送这样的报文。

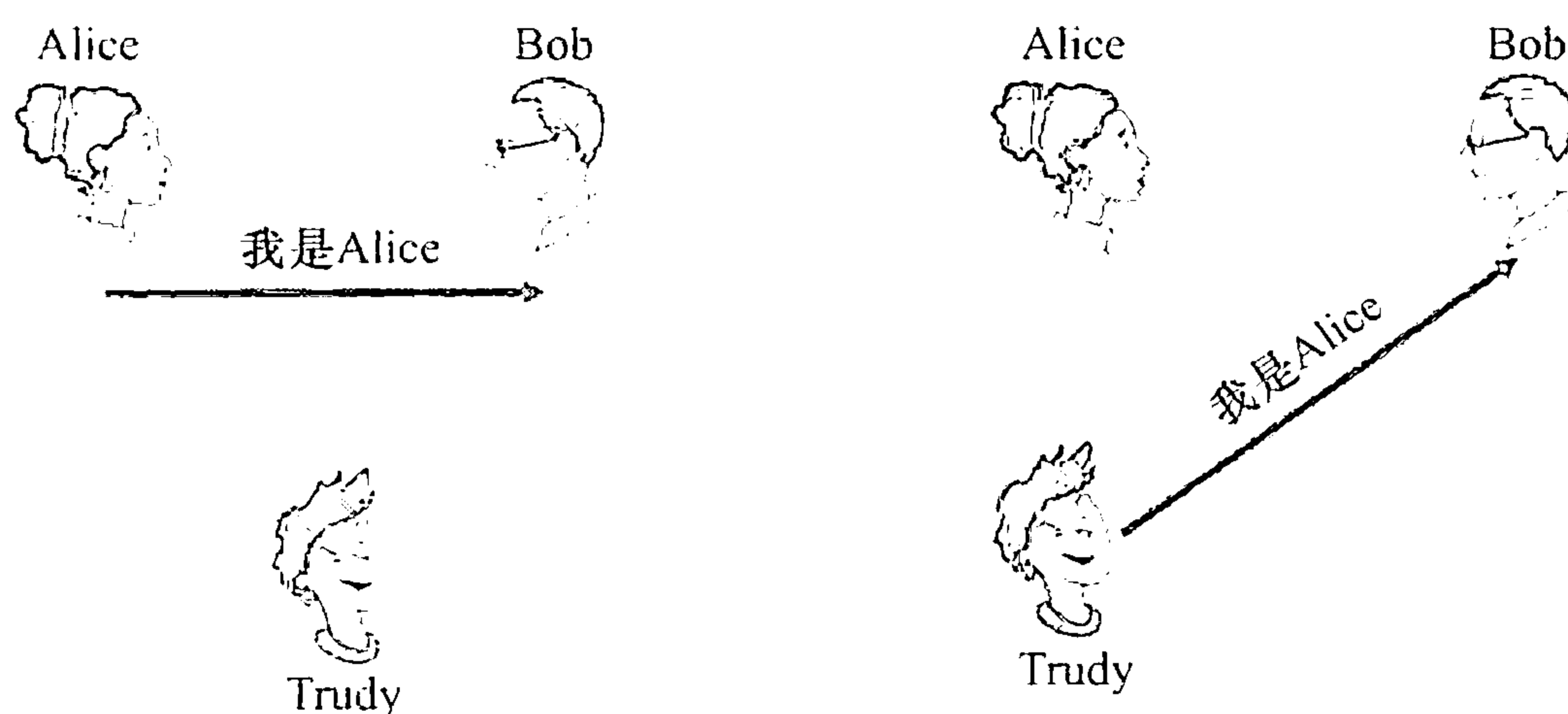


图 8-15 协议 ap1.0 和一种失败的情况

8.4.2 鉴别协议 ap2.0

如果 Alice 有一个总是用于通信的周知网络地址（如一个 IP 地址），则 Bob 能够试图通过验证携带鉴别报文的 IP 数据报的源地址是否与 Alice 的周知 IP 地址相匹配来进行鉴别。在这种情况下，Alice 就可被鉴别了。这可能阻止对网络一无所知的人假冒 Alice，但是它却不能阻止决定学习本书的学生或许多其他人！

根据我们学习的网络层和数据链路层的知识，我们就会知道做下列事情并不困难（例如，如果一个人能够访问操作系统代码并能构建自己的操作系统内核——比如 Linux 和许多其他免费可用的操作系统）：生成一个 IP 数据报，并在 IP 数据报中填入我们希望的任意源地址（比如 Alice 的周知 IP 地址），再通过链路层协议把生成的数据报发送到第一跳路由器。此后，具有不正确源地址的数据报就会忠实地向 Bob 转发。这种方法显示在图 8-16 中，它是 IP 哄骗的一种形式。如果 Trudy 的第一跳路由器被设置为只转发包含 Trudy 的 IP 源地址的数据报，就可以避免 IP 哄骗 [RFC 2827]。然而，这一措施并未得到广泛采用或强制实施。Bob 可能因为假定 Trudy 的网络管理员（这个管理员可能就是 Trudy 自己）已经配置 Trudy 的第一跳路由器，使之只能转发适当地址的数据报而被欺骗。

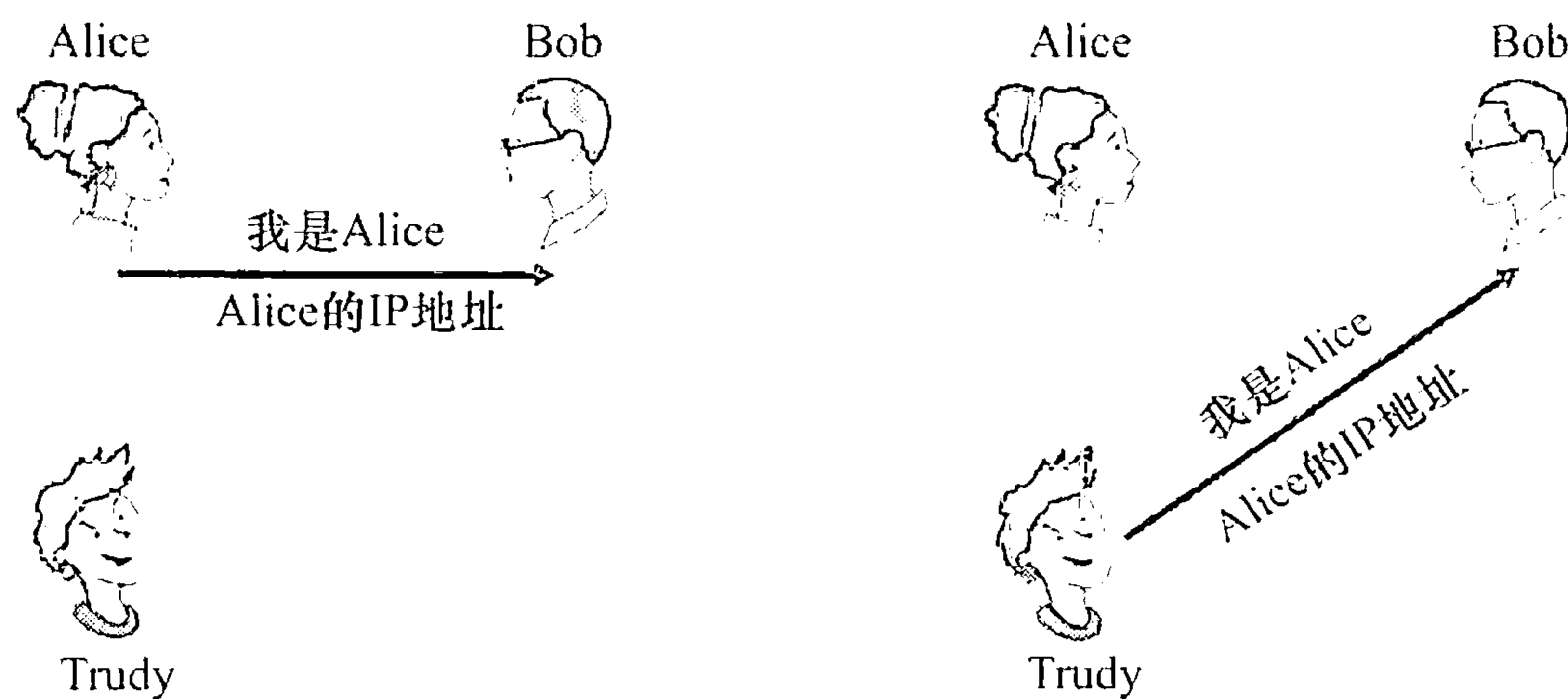


图 8-16 协议 ap2.0 和一种失败的情况

8.4.3 鉴别协议 ap3.0

进行鉴别的一种经典方法是使用秘密口令。口令是鉴别者和被鉴别者之间的一个共享秘密。Gmail、Telnet、FTP 和许多其他服务使用口令鉴别。在协议 ap3.0 中，Alice 因此向 Bob 发送其秘密口令，如图 8-17 所示。

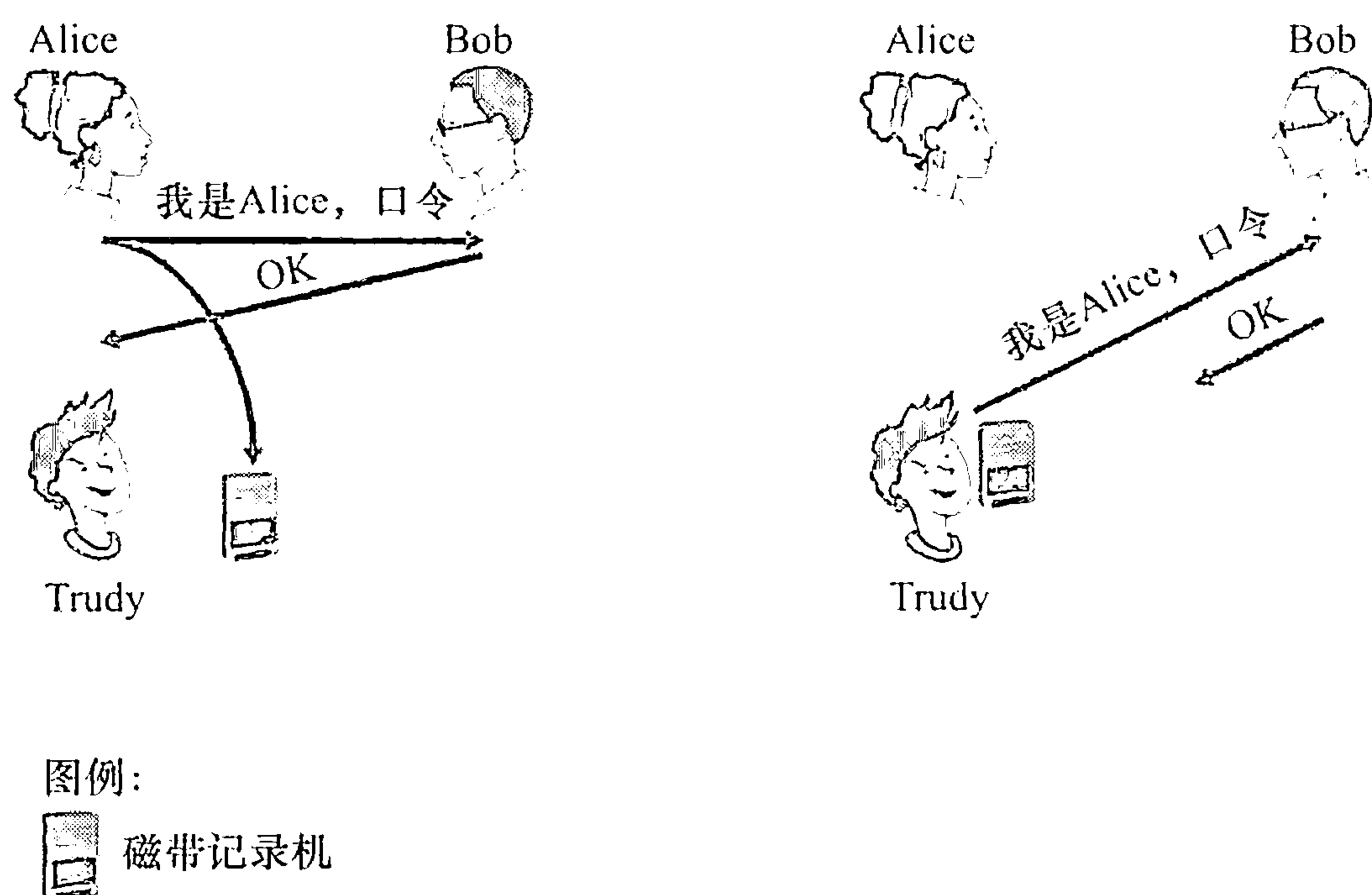


图 8-17 协议 ap3.0 和一种失败的情况

由于口令的广泛使用，我们也许猜想协议 ap3.0 相当安全。如果这样想，我们就错了！这里的安全性缺陷相当明显：如果 Trudy 窃听了 Alice 的通信，则可得到 Alice 的口令。为了使你认识到这种可能性，考虑这样的事实，当你 Telnet 到另一个机器上并登录时，登录口令未加密就发送到了 Telnet 服务器。连接到 Telnet 客户或服务器 LAN 的某个人都可能嗅探（sniff）（读并存储）在局域网上传输的所有数据分组，并因此窃取到该注册口令。实际上，这是一种窃取口令的周知方法（例如，参见 [Jimenez 1997]）。这样的威胁显然是真实存在的，所以协议 ap3.0 明显也不可行。

8.4.4 鉴别协议 ap3.1

我们完善协议 ap3.0 的下一个想法自然就是加密口令了。通过加密口令，我们能够防止 Trudy 得知 Alice 的口令。如果我们假定 Alice 和 Bob 共享一个对称秘密密钥 K_{A-B} ，则 Alice 可以加密口令，并向 Bob 发送其识别报文“我是 Alice”和加密的口令。Bob 则解密

口令，如果口令正确则鉴别了 Alice。因为 Alice 不仅知道口令，而且知道用于加密口令的共享秘密密钥值，Bob 才可以轻松地鉴别 Alice 的身份。我们称这个协议为 ap3.1。

尽管协议 ap3.1 确实防止了 Trudy 得知 Alice 的口令，此处使用密码术并不能解决鉴别问题。Bob 受制于回放攻击 (playback attack)：Trudy 只需窃听 Alice 的通信，并记录下该口令的加密版本，并向 Bob 回放该口令的加密版本，以假装她就是 Alice。协议 ap3.1 中加密口令的使用，并未使它比图 8-17 中的协议 ap3.0 的局面有明显改观。

8.4.5 鉴别协议 ap4.0

图 8-17 中的失败的情况是因为 Bob 不能区分 Alice 的初始鉴别报文和后来入侵者回放的 Alice 的初始鉴别报文所致。也就是说，Bob 无法判断 Alice 是否还活跃（即当前是否还在连接的另一端），或他接收到的报文是否就是前面鉴别 Alice 时录制的回放。观察力极强的读者会记起 TCP 的三次握手协议需要处理相同的问题，如果接收的 SYN 报文段来自较早连接的一个 SYN 报文段的旧副本（重新传输）的话，TCP 连接的服务器一侧不会接受该连接。TCP 服务器一侧如何解决“判断客户是否真正还活跃”的问题呢？它选择一个很长时间内都不会再次使用的初始序号，然后把这个序号发给客户，然后等待客户以包含这个序号的 ACK 报文段来响应。此处我们能够鉴别目的采用同样的思路。

不重数 (nonce) 是在一个协议的生存期中只使用一次的数。也就是说，一旦某协议使用了一个不重数，就永远不会再使用那个数字了。协议 ap4.0 以如下方式使用一个不重数：

- 1) Alice 向 Bob 发送报文“我是 Alice”。
- 2) Bob 选择一个不重数 R ，然后把这个值发送给 Alice。
- 3) Alice 使用她与 Bob 共享的对称秘密密钥 K_{A-B} 来加密这个不重数，然后把加密的不重数 $K_{A-B}(R)$ 发回给 Bob。与在协议 ap3.1 中一样，由于 Alice 知道 K_{A-B} 并用它加密一个值，就使得 Bob 知道收到的报文是由 Alice 产生的。这个不重数用于确定 Alice 是活跃的。
- 4) Bob 解密接收到的报文。如果解密得到的不重数等于他发送给 Alice 的那个不重数，则可鉴别 Alice 的身份。

协议 ap4.0 如图 8-18 所示。通过使用这个在生存期中只出现一次的值 R ，然后核对返回的值 $K_{A-B}(R)$ ，Bob 能够确定两点：Alice 是她所声称的那个人（因为她知道加密 R 所需的秘密密钥），Alice 是活跃的（因为她已经加密了 Bob 刚刚产生的不重数 R ）。

不重数和对称密钥密码体制的使用形成了 ap4.0 的基础。一个自然的问题是，我们是否能够使用不重数和公开密钥密码体制（而不是对称密钥密码体制）来解决鉴别问题？这个问题将在本章后面的习题中进行探讨。

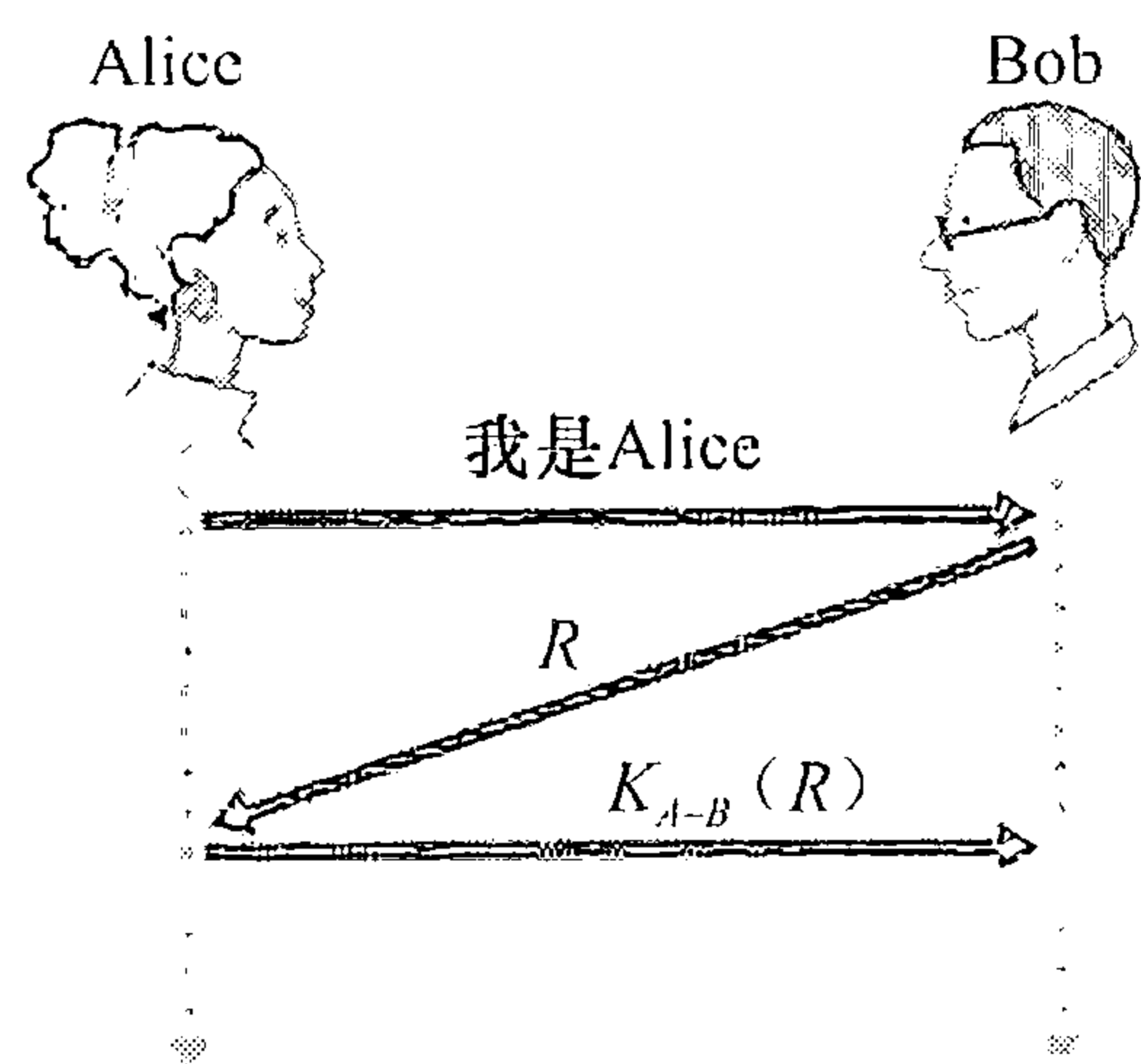


图 8-18 协议 ap4.0：无失败的情况

8.5 安全电子邮件

在前面的各节中，我们分析了网络安全中的基本问题，包括对称密钥密码体制和公开密钥密码体制、端点鉴别、密钥分发、报文完整性和数字签名。我们现在着手研究如何使

用这些工具在因特网中提供安全性。

有趣的是，为因特网协议栈上面 4 层的任一层提供安全性服务是可能的。当为某一特定的应用层协议提供安全性时，则使用这一协议的应用程序将能得到一种或多种安全服务，诸如机密性、鉴别或完整性。为某一运输层协议提供安全性时，则所有使用这一协议的应用程序都可以得到该运输层协议所提供安全性服务。在基于主机到主机的网络层提供安全性时，则所有运输层报文段（当然也包括所有应用层数据）都可以得到该网络层所提供的安全服务。当基于一条链路提供安全性时，则经过这个链路传输的所有帧中的数据都得到了该链路提供的安全性服务。

在 8.5 ~ 8.8 节中，我们考察了如何在应用层、运输层、网络层和数据链路层中使用这些安全性工具。为了与本书的整体框架保持一致，我们从协议栈的顶层开始，讨论在应用层的安全性。我们的方法是使用特定的应用程序如电子邮件，作为应用层安全性的一个学习案例。然后我们沿协议栈向下，分析 SSL 协议（它在运输层提供安全性）、IPsec 协议（它在网络层提供安全性），以及 IEEE 802.11 无线局域网协议的安全性。

你可能会感到奇怪：为什么要在因特网的多个层次上提供安全性功能呢？仅在网络层提供安全性功能并加以实施还不足够吗？对这个问题有两个答案。首先，尽管可以通过加密数据报中的所有数据（即所有的运输层报文段），以及通过鉴别所有数据报的源 IP 地址，在网络层能够提供“地毯式覆盖”安全性，但是却并不能提供用户级的安全性。例如，一个商业站点不能依赖 IP 层安全性来鉴别一个在该站点购买商品的顾客。因此，此处除了较低层的地毯式覆盖安全性外，还需要更高层的安全性功能。第二，在协议栈的较高层上部署新的因特网服务（包括安全性服务）通常较为容易。而等待在网络层上广泛地部署安全性，可能还需要未来若干年才能解决，许多应用程序的开发者“着手做起来”，并在他们中意的应用程序中引入安全性功能。一个典型的例子就是 PGP (Pretty Good Privacy)，它提供了安全电子邮件（将在本节后面讨论）。由于只需要客户和服务器应用程序代码，PGP 是第一个在因特网上得到广泛应用的安全性技术。

8.5.1 安全电子邮件

我们现在使用 8.2 ~ 8.3 节的密码学原则来生成一个安全电子邮件系统。我们以递进的方式来产生这个高层设计，每一步引入一些新安全性服务。当设计安全电子邮件系统时，我们需要记住最初在 8.1 节中所介绍的那个有趣的例子，即 Alice 和 Bob 之间的风流韵事。设想一下 Alice 发送一个电子邮件报文给 Bob，而 Trudy 试图入侵的情况。

在做出为 Alice 和 Bob 设计一个安全电子邮件系统的努力之前，我们应当首先考虑他们最为希望的安全特性是什么。重中之重是机密性。正如 8.1 节讨论的那样，Alice 或 Bob 都不希望 Trudy 阅读到 Alice 所发送的电子邮件报文。Alice 和 Bob 最希望在该电子邮件系统中看到的第二种特性是具备发送方鉴别。特别是，当 Bob 收到这样的报文 “I don't love you anymore. I never want to see you again. Formerly yours, Alice（我不再爱你了。我再也不想看到你了。Alice）” 时，Bob 自然而然地要确定这个报文确实来自 Alice，而非 Trudy 发送的。另外，这两个情人欣赏的另一种特性是报文完整性，也就是说，确保 Alice 所发的报文在发送给 Bob 的过程中没有被改变。最后，电子邮件系统应当提供接收方鉴别；即 Alice 希望确定她的确正在向 Bob 发信，而不是向假冒 Bob 的其他人（如 Trudy）发信。

因此我们从处理最为关注的机密性开始。提供机密性的最直接方式是 Alice 使用对称

密钥技术（如 DES 或 AES）加密所要传输的报文，而 Bob 则在接收时对报文解密。如 8.2 节讨论的那样，如果对称密钥足够长，且仅有 Alice 和 Bob 拥有该密钥，则其他人（包括 Trudy）要想读懂这条报文极为困难。尽管这种方法直截了当，但因为仅有 Alice 和 Bob 具有该密钥的副本，这使得分发对称密钥非常困难（我们在 8.2 节中讨论过）。因此我们自然就考虑用其他方法——公开密钥密码（例如使用 RSA）。在公开密钥方法中，Bob 使得他的公钥为公众所用（例如，从一台公钥服务器或其个人网页上得到），Alice 用 Bob 的公钥加密她的报文，然后向 Bob 的电子邮件地址发送该加密报文。当 Bob 接收到这个报文时，只需用他的私钥即可解密之。假定 Alice 确定得到的公钥是 Bob 的公钥，这种方法是提供所希望的机密性的极好方法。然而，存在的一个问题是公开密钥加密的效率相对低下，尤其对于长报文更是如此。

为了克服效率问题，我们利用了会话密钥（在 8.2.2 节中讨论过）。具体来说：
 ① Alice 选择一个随机对称会话密钥 K_S ；
 ② 用这个对称密钥加密她的报文 m ；
 ③ 用 Bob 的公钥 K_B^+ 加密这个对称密钥；
 ④ 级联该加密的报文和加密的对称密钥以形成一个“包”；
 ⑤ 向 Bob 的电子邮件地址发送这个包。这些过程显示在图 8-19 中（在这张图和下一张图中，带圈的“+”表示级联，带圈的“-”表示级联的分解）。当 Bob 接收到这个包时：
 ① 他使用其私钥 K_B^- 得到对称密钥 K_S ；
 ② 使用这个对称密钥 K_S 解密报文 m 。

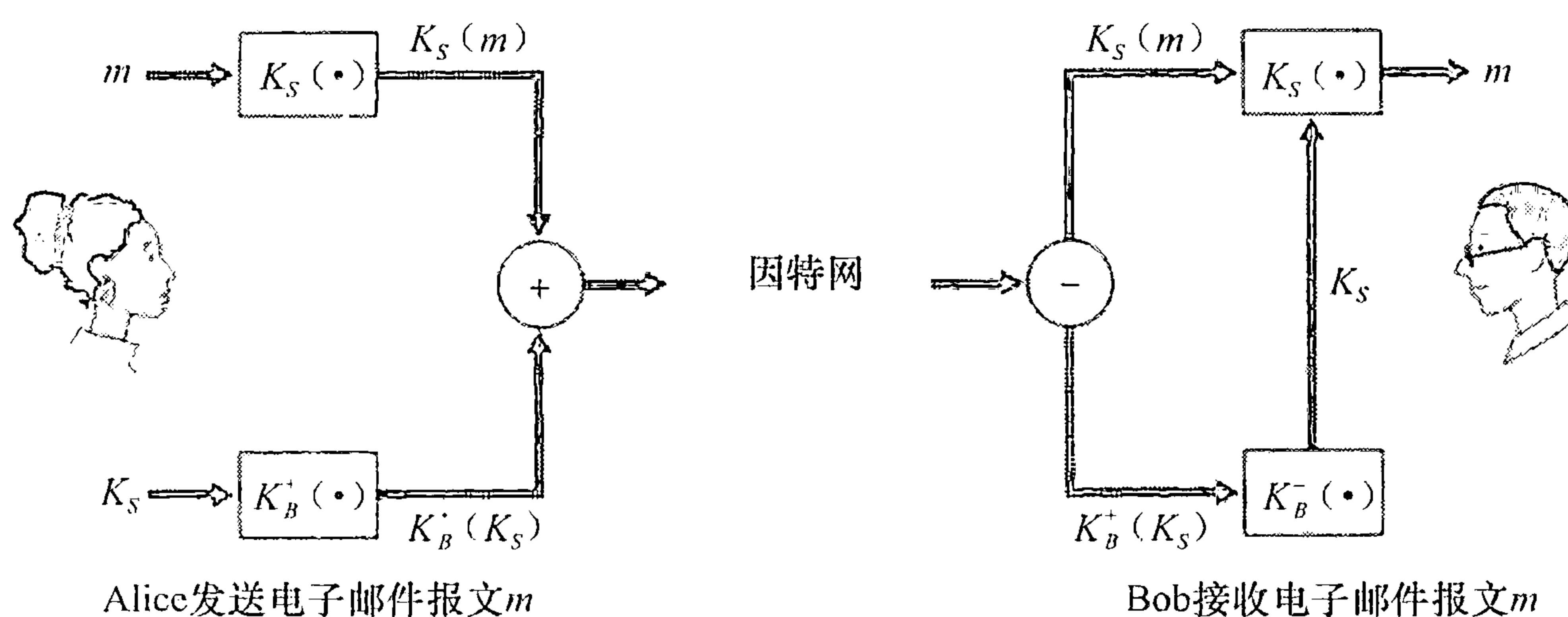


图 8-19 Alice 使用一个对称会话密钥 K_S 向 Bob 发送一个安全电子邮件

设计完提供机密性的安全电子邮件系统后，现在我们设计另一个可以提供发送方鉴别和报文完整性的系统。我们暂且假设 Alice 和 Bob 目前不关心机密性（他们要和其他人分享他们的爱情！），只关心发送方鉴别和报文完整性。为了完成这个任务，我们使用如 8.3 节所描述的数字签名和报文摘要。具体说来：
 ① Alice 对她要发送的报文 m 应用一个散列函数 H （例如 MD5），从而得到一个报文摘要；
 ② 用她的私钥 K_A^- 对散列函数的结果进行签名，从而得到一个数字签名；
 ③ 把初始报文（未加密）和该数字签名级联起来生成一个包；
 ④ 向 Bob 的电子邮件地址发送这个包。当 Bob 接收到这个包时：
 ① 他将 Alice 的公钥 K_A^+ 应用到被签名的报文摘要上；
 ② 将该操作的结果与他自己对该报的散列 H 进行比较。在图 8-20 中阐述了这些步骤。如 8.3 节中所讨论，如果这两个结果相同，则 Bob 完全可以确信这个报文来自 Alice 且未被篡改。

现在我们考虑设计一个提供机密性、发送方鉴别和报文完整性的电子邮件系统。这可以通过把图 8-19 和图 8-20 中的过程结合起来而实现。Alice 首先生成一个预备包，它与图 8-20 中的包完全相同，其中包含她的初始报文和该报文数字签名过的散列。然后 Alice

把这个预备包看作一个报文，再用图 8-19 中的发送方的步骤发送这个新报文，即生成一个新包发给 Bob。Alice 所做的这些步骤如图 8-21 所示。当 Bob 接收到这个包后，他首先应用图 8-19 中他这一侧的步骤，然后再应用图 8-20 中他这一侧的步骤。应当明确这一设计的目标是提供机密性、发送方鉴别和报文完整性。注意到在这一方案中，Alice 两次使用了公开密钥密码：一次用了她的私钥，另一次用了 Bob 的公钥。同样，Bob 也两次使用了公开密钥密码：一次用了他的私钥，一次用了 Alice 的公钥。

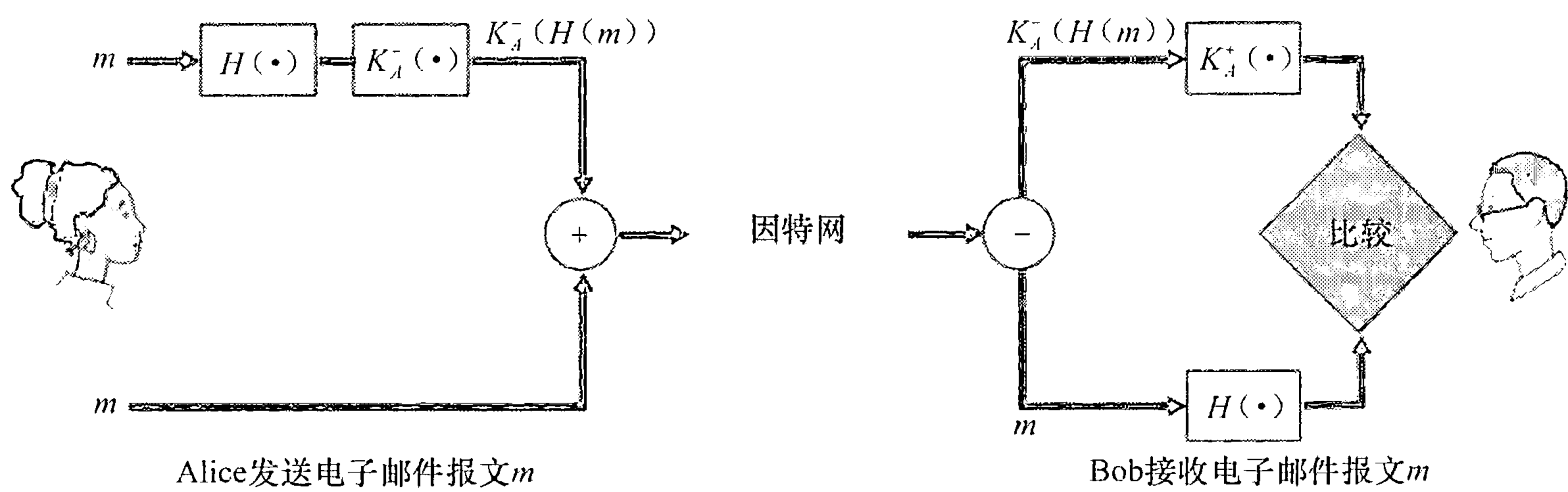


图 8-20 使用散列函数和数字签名来提供发送方鉴别和报文完整性

图 8-21 所示的安全电子邮件系统可能在大多数情况下都能为大多数电子邮件用户提供满意的安全性。但是仍有一个重要的问题没有解决。图 8-21 中的设计要求 Alice 获得 Bob 的公钥，也要求 Bob 获得 Alice 的公钥。但这些公钥的分发并不是一个小问题。例如，Trudy 可能假冒 Bob，发给 Alice 她自己的公钥，并告诉 Alice 这个公钥是 Bob 的公钥，使得 Trudy 就能接收到 Alice 发给 Bob 的报文。如我们在 8.3 节所学，安全地分发公钥的一种常用方法是通过 CA 验证该公钥。

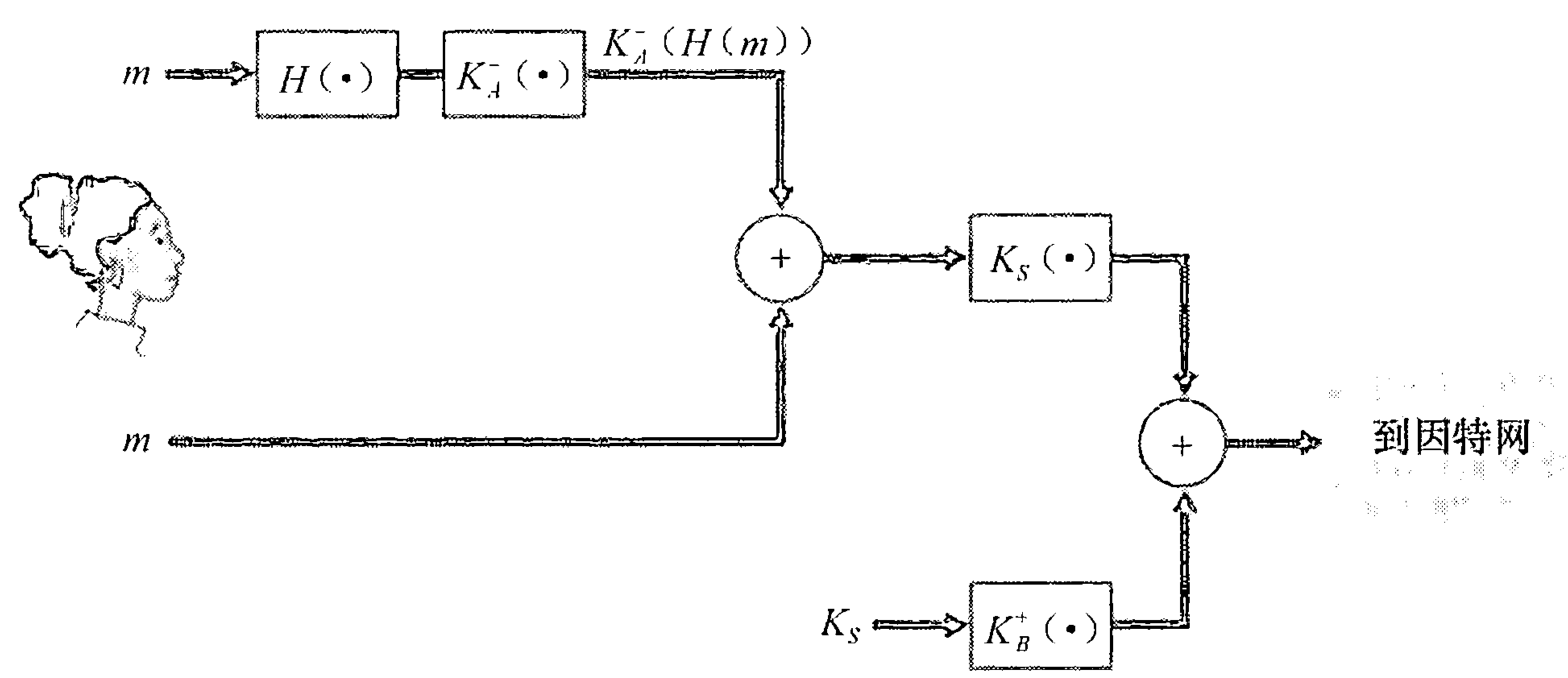


图 8-21 Alice 使用对称密钥密码、公开密钥密码、散列函数和数字签名来提供安全性、发送方鉴别和报文完整性

历史事件

Philip Zimmermann 和 PGP

Philip R. Zimmermann 是 PGP (Pretty Good Privacy) 的创造者。他因此在长达三年的时间里成为犯罪调查的目标，因为美国政府认为在 1991 年以后的时间里，PGP 在世界范围内以免费软件形式发布，违反了美国对加密软件出口的限制。在 PGP 作为共享软件

发布后，有人把 PGP 放到了因特网上，美国以外的外国人也可以下载它。在美国，加密程序分类为军用品，依据联邦法律不得出口到国外。

尽管缺乏资金，没有收入，也没有公司的支持，还要受到政府的干预，但 PGP 还是成为了世界上广泛使用的电子邮件加密软件。奇怪的是，因为 Zimmermann 案件，美国政府无意中促进了 PGP 的传播。

美国政府在 1996 年初放弃了这个案子。这一声明得到了许多因特网团体的喝彩。Zimmermann 案件已经成为无辜的个人为了自己的权益反抗强大的政府滥用职权的历史。政府的让步是值得庆幸的事，部分原因是由于在国会中对因特网审查制度的游说，以及 FBI 推动允许越来越多的政府侦听。

在政府撤案后，Zimmermann 建立了 PGP 公司，该公司于 1997 年 12 月并入网络联盟（Network Associates）。Zimmermann 现在是密码学领域中一位独立咨询者。

8.5.2 PGP

Philip Zimmermann 于 1991 年所写的 PGP（Pretty Good Privacy）是一个电子邮件加密方案，如今已经成为一个事实上的标准。其 Web 站点以每个月百万页的规模，为在 166 个国家的用户提供服务 [PGPI 2012]。在公共领域中有各种版本的 PGP 可供使用；例如，你能够在国际 PGP 的主页上为你喜爱的平台找到 PGP 软件以及许多有趣的读物 [PGPI 2012]。（特别是 PGP 作者所撰写的一篇特别有趣的文章 [Zimmermann 2012]。）PGP 的设计在本质上和图 8-21 中所示的设计相同。PGP 软件的不同版本使用 MD5 或使用 SHA 来计算报文摘要；使用 CAST、三重 DES 或 IDEA 进行对称密钥加密；使用 RSA 进行公开密钥加密。

安装 PGP 时，软件为用户产生一个公开密钥对。该公钥能被张贴到用户的网站上或放置在某台公钥服务器上。私钥则使用用户口令进行保护。用户每次访问私钥时都要输入这个口令。PGP 允许用户选择是否对报文进行数字签名、加密报文，或同时进行数字签名和加密。图 8-22 显示了一个 PGP 签名的报文。这个报文在 MIME 首部之后出现。报文中的加密数据为 $K_A^-(H(m))$ ，即数字签名的报文摘要。如我们上述讨论，Bob 为了验证报文的完整性，需要得到 Alice 的公钥。

```
-----BEGIN PGP SIGNED MESSAGE-----
Hash:  SHA1
Bob:
Can I see you tonight?
Passionately yours, Alice
-----BEGIN PGP SIGNATURE-----
Version: PGP for Personal Privacy 5.0
Charset:  noconv
yhHJRhhGJGhg/12EpJ+lo8gE4vB3mqJhFEvZP9t6n7G6m5Gw2
-----END PGP SIGNATURE-----
```

图 8-22 PGP 签名报文

图 8-23 显示了一个秘密 PGP 报文。这个报文也出现在 MIME 首部之后。当然，明文报文不包括在这个秘密电子邮件报文中。当一个发送方（例如 Alice）要确保机密性和完整性时，PGP 在如图 8-23 所示的报文中包含一个类似于图 8-22 中的报文。


```
-----BEGIN PGP MESSAGE-----  
Version: PGP for Personal Privacy 5.0  
u2R4d+/jKmn8Bc5+hgDsqAewsDfrGdszX68liKm5F6Gc4sDfcXyt  
RfdS10juHgbcfDssWe7/K=1KhnMikLo0+l/BvcX4t==Ujk9PbcD4  
Thdf2awQfgHbnmKlok8iy6gThlp  
-----END PGP MESSAGE
```

图 8-23 一个秘密 PGP 报文

PGP 也提供了一种公钥认证机制，但是这种机制与更为传统的 CA 差异很大。PGP 公钥由一个可信 Web 验证。当 Alice 相信一个密钥/用户名对确实匹配时，她自己就可以验证这一密钥/用户名对。此外，PGP 允许 Alice 为她所信任的用户鉴别更多密钥提供担保。一些 PGP 用户通过保持密钥签署方（key-signing party）互相签署对方的密钥。用户实际走到一起，交换公钥，并用自己的私钥对对方的公钥签名来互相验证密钥。

8.6 使 TCP 连接安全：SSL

在前一节中，我们看到对一个特定的应用（即电子邮件），密码技术是怎样提供机密性、数据完整性和端点鉴别的。在这一节中，我们在协议栈中向下一层，考察密码技术如何用安全性服务加强 TCP，该安全性服务包括机密性、数据完整性和端点鉴别。TCP 的这种强化版本通常被称为安全套接字层（Secure Socket Layer, SSL）。SSL 版本 3 的一个稍加修改的版本被称为运输层安全性（Transport Layer Security, TLS），已经由 IETF 标准化 [RFC 4346]。

SSL 最初由 Netscape 设计，而使 TCP 安全隐含的基本思想先于 Netscape 的工作（例如，参见 [Woo 1994]）。由于 SSL 的崭露头角，它已经得到了广泛部署。SSL 得到了所有流行 Web 浏览器和 Web 服务器的支持，并基本上被用于所有因特网商业站点（包括 Amazon、eBay、Yahoo!、MSN 等等）。每年经 SSL 花费了数百亿美元。事实上，如果你使用信用卡通过因特网购买任何东西的话，在你的浏览器和服务器之间的通信几乎一定使用了 SSL。（当你使用浏览器时，若 URL 以 https: 开始而不是以 http 开始，就能认定正在使用 SSL。）

为了理解 SSL 的需求，我们浏览一下某典型的因特网商业的场景。Bob 在 Web 上冲浪，到达了 Alice 公司的站点，这个站点正在出售香水。Alice 公司站点显示了一个表格，假定 Bob 可以在该表格中输入香水的类型和所希望的数量、他的地址和他的支付卡号等信息。Bob 输入这些信息，点击“提交”，就期待收到（通过普通邮政邮件）所购买的香水；他也期待着在他的下一次支付卡报表中收到对所购物品的支付信息。所有这一切听起来不错，但是如果不采取安全措施，Bob 也许会有一些意外。

- 如果没有使用机密性（加密），一个入侵者可能截取 Bob 的订单并得到他的支付卡信息。这个入侵者则可以用 Bob 的费用来购买商品。
- 如果没有使用完整性，入侵者可能修改 Bob 的订单，让他购买比希望瓶数多 10 倍的香水。
- 最后，如果没有使用服务器鉴别，这个显示 Alice 公司著名徽标的服务器实际上是由 Trudy 维护的一个站点，Trudy 正在假冒 Alice 公司。当 Trudy 收到 Bob 的订单后，可能拿了 Bob 的钱一走了之。或者 Trudy 可能充当一名身份窃贼，收集 Bob 的名字、地址和信用卡号。

SSL 通过采用机密性、数据完整性、服务器鉴别和客户鉴别来强化 TCP，就可以解决

这些问题。

SSL 经常用来为发生在 HTTP 之上的事务提供安全性。然而，因为 SSL 使 TCP 安全了，因此它能被应用于运行在 TCP 之上的任何应用程序。SSL 提供了一个简单的具有套接字的应用编程接口（API），该接口类似于 TCP 的 API。当一个应用程序要使用 SSL 时，它包括了 SSL 类/库。如在图 8-24 中所示，尽管 SSL 技术上位于应用层中，但从研发者的角度看，它是一个提供 TCP 服务的运输协议，而这里的 TCP 服务用安全性服务加强了。

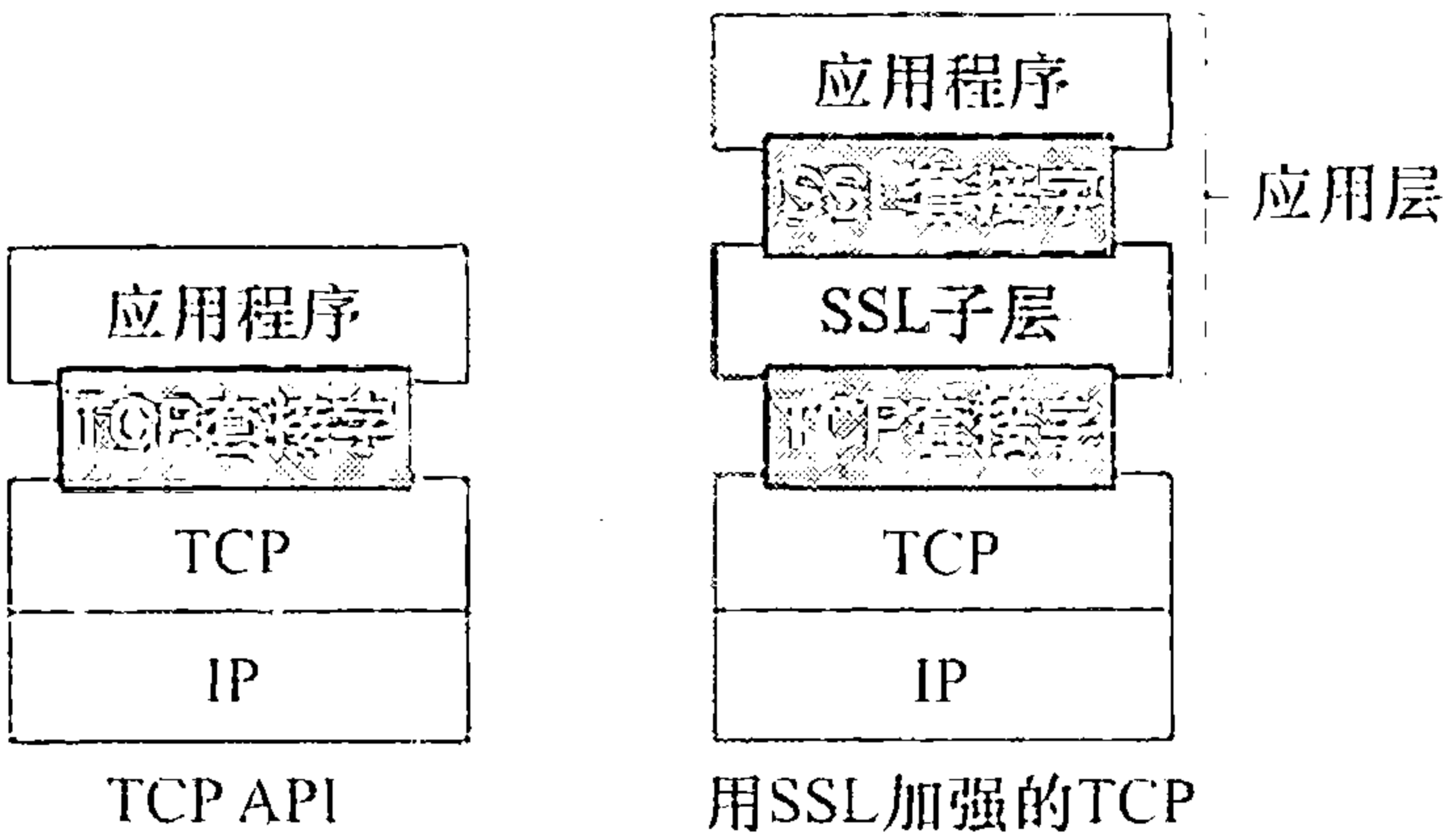


图 8-24 尽管 SSL 技术上位于应用层中，但从研发者的角度看它是一个运输协议

8.6.1 宏观描述

我们从描述一个简化的 SSL 版本开始，这将使我们从宏观上理解 SSL 的工作原理和工作过程。我们将这个 SSL 的简化版本称之为“类 SSL”。描述过类 SSL 之后，在下一小节中我们将描述真实的 SSL，填充细节。类 SSL（和 SSL）具有三个阶段：握手、密钥导出和数据传输。我们现在描述针对一个客户（Bob）和一个服务器（Alice）之间的通信会话的这三个阶段，其中 Alice 具有私钥/公钥对和将她的身份与其公钥绑定的证书。

1. 握手

在握手阶段，Bob 需要：①与 Alice 创建一条 TCP 连接；②验证 Alice 是真实的 Alice；③发送给 Alice 一个主密钥，Bob 和 Alice 持用该主密钥生成 SSL 会话所需的所有对称密钥。这三个步骤显示在图 8-25 中。注意到一旦创建了 TCP 连接，Bob 就向 Alice 发送一个 hello 报文。Alice 则用她的证书进行响应，证书中包含了她的公钥。如在 8.3 节所讨论，因为该证书已被某 CA 证实过，Bob 明白无误地知道该公钥属于 Alice。然后，Bob 产生一个主密钥（MS）（该 MS 将仅用于这个 SSL 会话），用 Alice 的公钥加密该 MS 以生成加密的主密钥（EMS），并将该 EMS 发送给 Alice。Alice 用她的私钥解密该 EMS 从而得到该 MS。在这个阶段后，Bob 和 Alice（而无别的人）均知道了用于这次 SSL 会话的主密钥。

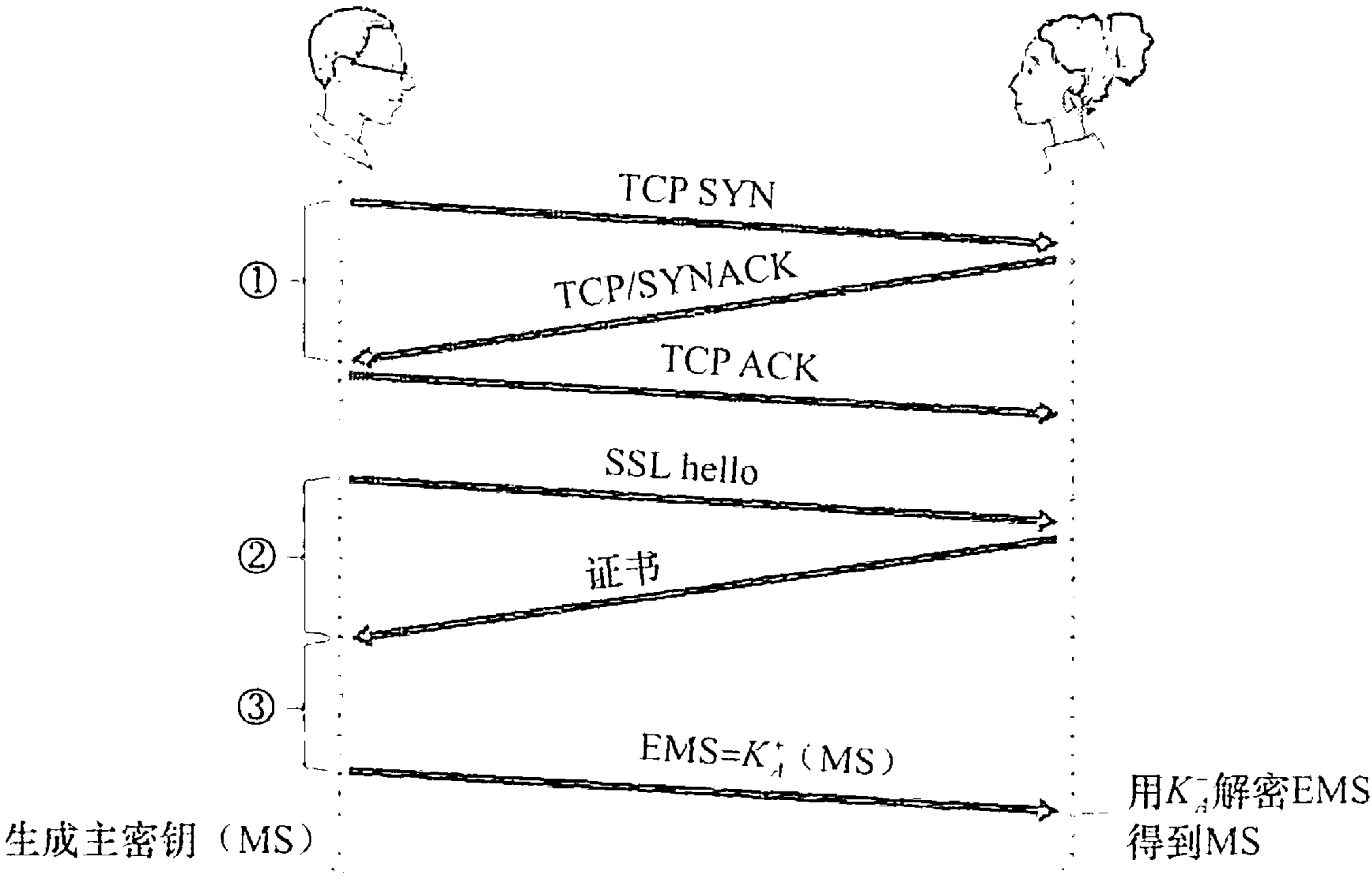


图 8-25 类 SSL 握手，首先建立一个 TCP 连接

2. 密钥导出

从原则上讲，MS 此时已由 Bob 和 Alice 共享，它能够用作所有后继加密和数据完整性检查的对称会话密钥。然而，对于 Alice 和 Bob 每人而言，使用不同的密码密钥，并且对于加密和完整性检查也使用不同的密钥，通常认为更为安全。因此，Alice 和 Bob 都使用 MS 生成 4 个密钥：

- E_B ，用于从 Bob 发送到 Alice 的数据的会话加密密钥
- M_B ，用于从 Bob 发送到 Alice 的数据的会话 MAC 密钥
- E_A ，用于从 Alice 发送到 Bob 的数据的会话加密密钥
- M_A ，用于从 Alice 发送到 Bob 的数据的会话 MAC 密钥

Alice 和 Bob 每人都从 MS 生成 4 个密钥。这能够通过直接将该 MS 分为 4 个密钥来实现。（但在真实的 SSL 中更为复杂一些，我们后面将会看到。）在密钥导出阶段结束时，Alice 和 Bob 都有了 4 个密钥。其中的两个加密密钥将用于加密数据；两个 MAC 密钥将用于验证数据的完整性。

3. 数据传输

既然 Alice 和 Bob 共享相同的 4 个会话密钥（ E_B ， M_B ， E_A 和 M_A ），他们就能够经 TCP 连接开始发送安全的数据。因为 TCP 是一种字节流协议，一种自然的方法是用 SSL 在传输中加密应用数据，然后将加密的数据在传输中传给 TCP。但是如果我们真的这样做，我们将用于完整性检查的 MAC 置于何处呢？我们无疑不希望等到 TCP 会话结束时才验证所有 Bob 数据的完整性，Bob 数据的发送要经历整个会话！为了解决这个问题，SSL 将数据流分割成记录，对每个记录附加一个 MAC 用于完整性检查，然后加密该“记录 + MAC”。为了产生这个 MAC，Bob 将数据连同密钥 M_B 放入一个散列函数中，如在 8.3 节所讨论。为了加密“记录 + MAC”这个包，Bob 使用他的会话加密密钥 E_B 。然后这个加密的包将传递给 TCP 经因特网传输。

虽然这种方法几经周折，但它为整个报文流提供数据完整性时仍未达到无懈可击。特别是，假定 Trudy 是一名“中间人”，并且有在 Alice 和 Bob 之间发送的 TCP 报文段流中插入、删除和代替报文段的能力。例如，Trudy 能够俘获由 Bob 发送的两个报文段，颠倒这两个报文段的次序，调整 TCP 报文段的序号（这些未被加密），然后将这两个次序翻转的报文段发送给 Alice。假定每个 TCP 报文段正好封装了一个记录，我们现在看看 Alice 将如何处理这些报文段。

- 1) 在 Alice 端运行的 TCP 将认为一切正常，将这两个记录传递给 SSL 子层。
- 2) 在 Alice 端的 SSL 将解密这两个记录。
- 3) 在 Alice 端的 SSL 将使用在每个记录中的 MAC 来验证这两个记录的数据完整性。
- 4) 然后 SSL 将解密的两条记录的字节流传递给应用层；但是 Alice 收到的完整字节流由于记录的颠倒而次序不正确！

鼓励读者观察类似的场景，如当 Trudy 删除报文段或当 Trudy 重放报文段时。

对该问题的解决方案如你可能猜想的那样，那就是使用序号。SSL 采用如下的方式。Bob 维护一个序号计数器，计数器开始为 0，Bob 每发送的一个 SSL 记录它都增加 1。Bob 并不实际在记录中包括一个序号，但当他计算 MAC 时，他把该序号包括在 MAC 的计算中。所以，该 MAC 现在是数据加 MAC 密钥 M_B 加当前序号的散列。Alice 跟踪 Bob 的序

号，通过在 MAC 的计算中包括适当的序号，使她验证一条记录的数据完整性。SSL 序号的使用阻止了 Trudy 执行诸如重排序或重放报文段等中间人攻击。（为什么？）

4. SSL 记录

SSL 记录（以及类 SSL 记录）显示在图 8-26 中。该记录由类型字段、版本字段、长度字段、数据字段和 MAC 字段组成。注意到前三个字段是不加密的。类型字段指出了该字段是握手报文还是包含应用数据的报文。它也用于关闭 SSL 连接，如下面所讨论。在接收端的 SSL 使用长度字段以从到达的 TCP 字节流中提取 SSL 记录。版本字段是自解释的。

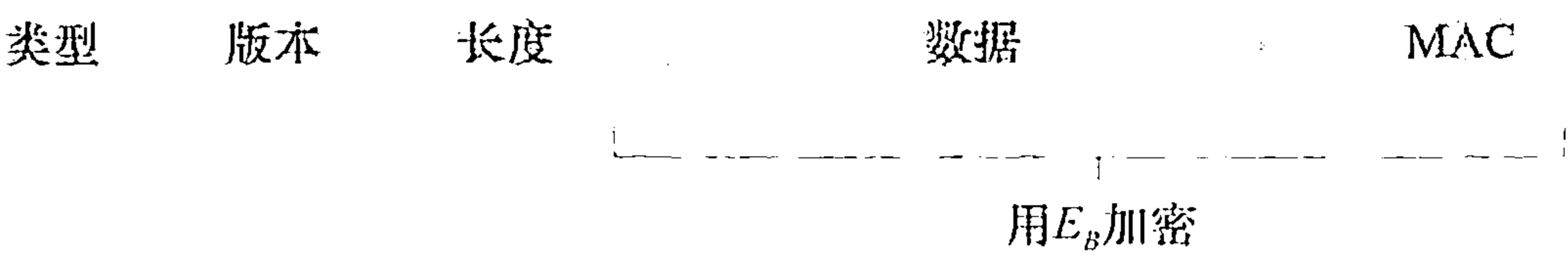


图 8-26 SSL 记录格式

8.6.2 更完整的描述

前一小节涉及了类 SSL 协议；其目的是让我们对 SSL 的工作原理和工作过程有一个基本理解。既然我们已经对 SSL 有了基本了解，就能够更深入地研究实际 SSL 协议的要点了。为了配合阅读对 SSL 协议的描述，鼓励读者完成 Wireshark SSL 实验，它在本书配套的 Web 网站上可供使用。

1. SSL 握手

SSL 并不强制 Alice 和 Bob 使用一种特定的对称密钥算法、一种特定的公钥算法或一种特定的 MAC。相反，SSL 允许 Alice 和 Bob 在握手阶段在 SSL 会话开始时就密码算法取得一致。此外，在握手阶段，Alice 和 Bob 彼此发送不重数，该数被用于会话密钥（ E_B ， M_B ， E_A 和 M_A ）的生成中。真正的 SSL 握手的步骤如下：

- 1) 客户发送它支持的密码算法的列表，连同同一个客户的不重数。
- 2) 从该列表中，服务器选择一种对称算法（例如 AES）、一种公钥算法（例如具有特定密钥长度的 RSA）和一种 MAC 算法。它把它的选择以及证书和一个服务器不重数返回给客户。
- 3) 客户验证该证书，提取服务器的公钥，生成一个前主密钥（Pre-Master Secret, PMS），用服务器的公钥加密该 PMS，并将加密的 PMS 发送给服务器。
- 4) 使用相同的密钥导出函数（就像 SSL 标准定义的那样），客户和服务器独立地从 PMS 和不重数中计算出主密钥（Master Secret, MS）。然后该 MS 被切片以生成两个密码和两个 MAC 密钥。此外，当选择的对称密码应用于 CBC（例如 3DES 或 AES），则两个初始化向量（Initialization Vector, IV）也从该 MS 获得，这两个 IV 分别用于该连接的两端。自此以后，客户和服务器之间发送的所有报文均被加密和鉴别（使用 MAC）。
- 5) 客户发送所有握手报文的一个 MAC。
- 6) 服务器发送所有握手报文的一个 MAC。

最后两个步骤使握手免受篡改危害。为了理解这一点，观察在第一步中，客户通常提供一个算法列表，其中有些算法强，有些算法弱。因为这些加密算法和密钥还没有被协商好，所以算法的这张列表以明文形式发送。Trudy 作为中间人，能够从列表中删除较强的

算法，迫使客户选择一种较弱的算法。为了防止这种篡改攻击，在步骤 5 中客户发送一个级联它已发送和接收的所有握手报文的 MAC。服务器能够比较这个 MAC 与它已接收和发送的握手报文的 MAC。如果有不一致，服务器能够终止该连接。类似地，服务器发送一个它已经看到的握手报文的 MAC，允许客户检查不一致性。

你可能想知道在步骤 1 和步骤 2 中存在不重数的原因。序号不足以防止报文段重放攻击吗？答案是肯定的，但它们并不只是防止“连接重放攻击”。考虑下列连接重放攻击。假设 Trudy 嗅探了 Alice 和 Bob 之间的所有报文。第二天，Trudy 冒充 Bob 并向 Alice 发送正好是前一天 Bob 向 Alice 发送的相同的报文序列。如果 Alice 没有使用不重数，她将以前一天发送的完全相同的序列报文进行响应。Alice 将不怀疑任何不规矩的事，因为她接收到的每个报文将通过完整性检查。如果 Alice 是一个电子商务服务器，她将认为 Bob 正在进行第二次订购（正好订购相同的東西）。在另一方面，在协议中包括了一个不重数，Alice 将对每个 TCP 会话发送不同的不重数，使得这两天的加密密钥不同。因此，当 Alice 接收到来自 Trudy 重放的 SSL 记录时，该记录将无法通过完整性检查，并且假冒的电子商务事务将不会成功。总而言之，在 SSL 中，不重数用于防御“连接重放”，而序号用于防御在一个进行中的会话中重放个别分组。

2. 连接关闭

在某个时刻，Bob 或者 Alice 将要终止 SSL 会话。一个方法是让 Bob 通过直接终止底层的 TCP 连接来结束该 SSL 会话，这就是说，通过让 Bob 向 Alice 发送一个 TCP FIN 报文段。但是这种幼稚设计为截断攻击（truncation attack）创造了条件，Trudy 再一次介入一个进行中的 SSL 会话中，并用 TCP FIN 过早地结束了该会话。如果 Trudy 这样做的话，Alice 将会认为她收到了 Bob 的所有数据，而实际上她仅收到了其中的一部分。对这个问题的解决方法是，在类型字段中指出该记录是否是用于终止该 SSL 会话的。（尽管 SSL 类型是以明文形式发送的，但在接收方使用了记录的 MAC 对它进行了鉴别。）通过包括这样一个字段，如果 Alice 在收到一个关闭 SSL 记录之前突然收到了一个 TCP FIN，她可能知道正在进行着某些耍花招的事情。

到此为止完成了对 SSL 的介绍。我们已经看到它使用了在 8.2 节和 8.3 节讨论的许多密码学原则。希望更深入地探讨 SSL 的读者可以阅读 Rescorla 的有关 SSL 的可读性很强的书籍 [Rescorla 2001]。

8.7 网络层安全性：IPsec 和虚拟专用网

IP 安全（IP Security）协议更常被称为 IPsec，它为网络层提供了安全性。IPsec 为任意两个网络层实体（包括主机和路由器）之间的 IP 数据报提供了安全。如我们很快要描述的那样，许多机构（公司、政府部门、非营利组织等等）使用 IPsec 创建了运行在公共因特网之上的虚拟专用网（virtual private network, VPN）。

在学习 IPsec 细节之前，我们后退一步来考虑为网络层提供机密性所包含的意义。在网络实体对之间（例如，两台路由器之间，两台主机之间，或者路由器和主机之间）具有网络层机密性，发送实体加密它发送给接收实体的所有数据报的载荷。这种载荷可以是一个 TCP 报文段、一个 UDP 报文段、一个 ICMP 报文等等。如果这样的网络层服务适当的话，从一个实体向其他实体发送的所有数据报将隐形于任何可能嗅探该网络的第三方，发

送的数据报包括电子邮件、Web 网页、TCP 握手报文和管理报文（例如 ICMP 和 SNMP）。正因为如此，网络层安全性被认为提供了“地毯覆盖”。

除了机密性，网络层安全协议潜在地能够提供其他安全性服务。例如，它能提供源鉴别，使得接收实体能够验证安全数据报的源。网络层安全协议能够提供数据完整性，使得接收实体能够核对在数据报传输过程中可能出现的任何篡改。网络层安全服务也能提供防止重放攻击功能，这意味着 Bob 能够检测任何攻击者可能插入的任何冗余数据报。我们将很快看到 IPsec 的确提供了用于这些安全服务的机制，即机密性、源鉴别、数据完整性和重放攻击防护。

8.7.1 IPsec 和虚拟专用网

跨越在多个地理区域上的某机构常常希望有自己的 IP 网络，使它的主机和服务器能够以一种安全和机密的方式彼此发送数据。为了达到这个目标，该机构能够实际部署一个单独的物理网络，该网络包括路由器、链路和 DNS 基础设施且与公共因特网完全分离。这样一种为特定的机构专用的分立网络被称为专用网络（private network）。毫不奇怪，专用网络可能耗资巨大，因为该机构需要购买、安装和维护它自己的物理网络基础设施。

不同于部署和维护一个专用网络，如今许多机构在现有的公共因特网上创建 VPN。使用 VPN，机构办公室之间的流量经公共因特网而不是经物理上独立的网络发送。而为了提供机密性，办公室之间的流量在进入公共因特网之前进行加密。图 8-27 中显示了 VPN 的一个简单例子。这里的机构由一个总部、一个分支机构和旅行中的销售员组成，销售员通常从他们的旅馆房间接入因特网。（在该图中仅显示了一名销售员。）在这个 VPN 中，无论何时，位于总部的两台主机相互发送 IP 数据报或位于分支机构的两台主机要通信，它们都使用经典的 IPv4（即无 IPsec 服务）。然而，当两台机构的主机经过跨越公共因特网的路径时，这些流量在进入因特网之前进行加密。

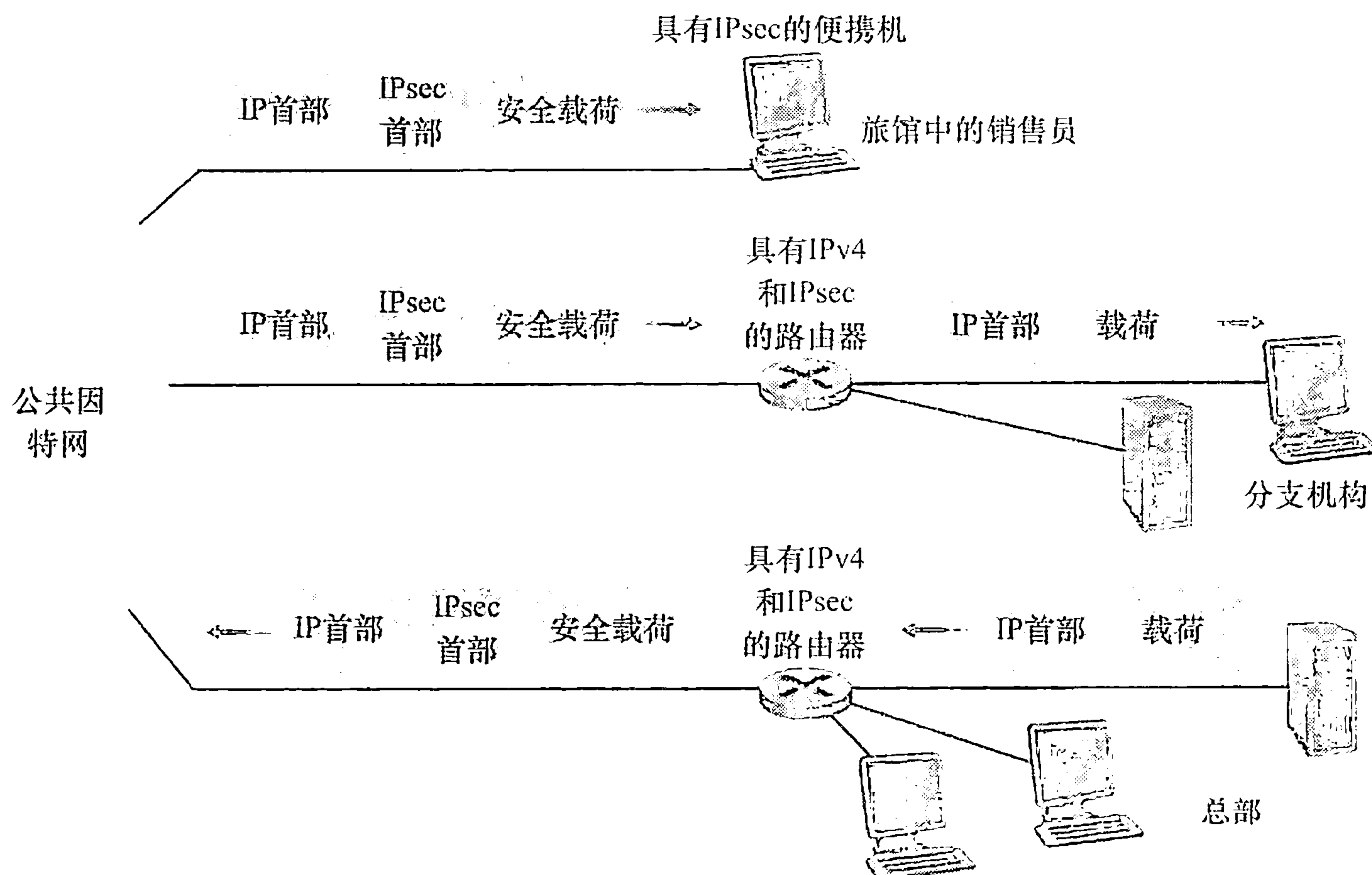


图 8-27 虚拟专用网

为了感受 VPN 的工作过程，我们浏览图 8-27 场景中的一个简单例子。当总部中的一台主机向某旅馆中的某销售员发送一个 IP 数据报时，总部中的网关路由器将经典的 IPv4 转换成为 IPsec 数据报，然后将该 IPsec 数据报转发进因特网。该 IPsec 数据报实际上具有传统的 IPv4 首部，因此在公共因特网中的路由器处理该数据报，仿佛它对路由器而言是一个普通的 IPv4 数据报。但是如图 8-27 所示，IPsec 数据报的载荷包括了一个 IPsec 首部，该首部被用于 IPsec 处理；此外，IPsec 数据报的载荷是被加密的。当该 IPsec 数据报到达销售员的便携机时，便携机的操作系统解密载荷（并提供其他安全服务，如验证数据完整性），并将解密的载荷传递给上层协议（例如，给 TCP 或 UDP）。

我们刚刚给出了某机构能够应用 IPsec 生成一个 VPN 的高层面的展望。为了通过局部看全局，我们已经去掉了许多重要的细节。现在我们来进行更深入的学习。

8.7.2 AH 协议和 ESP 协议

IPsec 是一个相当复杂的整体，即它被定义为 10 多个 RFC 文档。两个重要的文档是 RFC 4301 和 RFC 6071，前者描述了总体 IP 安全体系结构，后者提供了一个 IPsec 协议集的概述。在本教科书中我们的目标与往常一样，并不只是一味重复枯燥和晦涩难解的 RFC 文档，而是采用一种更具可操作性和易于教学的方法来描述协议。

在 IPsec 协议族中，有两个主要协议：鉴别首部（Authentication Header, AH）协议和封装安全性载荷（Encapsulation Security Payload, ESP）协议。当某源 IPsec 实体（通常是一台主机或路由器）向一个目的实体（通常也是一台主机或路由器）发送安全数据报时，它可以使用 AH 协议或 ESP 协议来做到。AH 协议提供源鉴别和数据完整性服务，但不提供机密性服务。ESP 协议提供了源鉴别、数据完整性和机密性服务。因为机密性通常对 VPN 和其他 IPsec 应用是至关重要的，所以 ESP 协议的使用比 AH 协议要广泛得多。为了讲清 IPsec 并且避免许多难题，我们将此后专门关注 ESP 协议。鼓励还想学习 AH 协议的读者研讨相关的 RFC 和其他在线资源。

8.7.3 安全关联

IPsec 数据报在网络实体对之间发送，例如两台主机之间、两台路由器之间或一台主机和一台路由器之间。在从源实体向目的实体发送 IPsec 数据报之前，源和目的实体创建了一个网络层的逻辑连接。这个逻辑连接称为安全关联（Security Association, SA）。一个 SA 是一个单工逻辑连接；也就是说，它是从源到目的地单向的。如果两个实体要互相发送安全数据报，则需创建两个 SA，每个方向一个。

例如，再次考虑图 8-27 中那个机构的 VPN。该机构由一个总部、一个分支机构和 n 个旅行销售员组成。为了举例的缘故，我们假设在总部和分支机构之间有双向 IPsec 流量，并且总部和销售员之间也有双向 IPsec 流量。在这个 VPN 中，有多少个 SA 呢？为了回答这个问题，注意到在总部网关路由器和分支机构网关路由器之间有两个 SA（一个方向一个）；对每个销售员的便携机而言，在总部网关和便携机之间有两个 SA（仍是一个方向一个）。因此，总计为 $(2 + 2n)$ 个 SA。然而记住，并非从网关路由器或便携机发送进因特网的所有流量都将是 IPsec 安全的。例如，总部中的一台主机可能要访问公共因特网中的某 Web 服务器（例如 Amazon 或谷歌）。因此，该网关路由器（或该便携机）将发送经典的 IPv4 数据报和安全的 IPsec 数据报进入因特网。

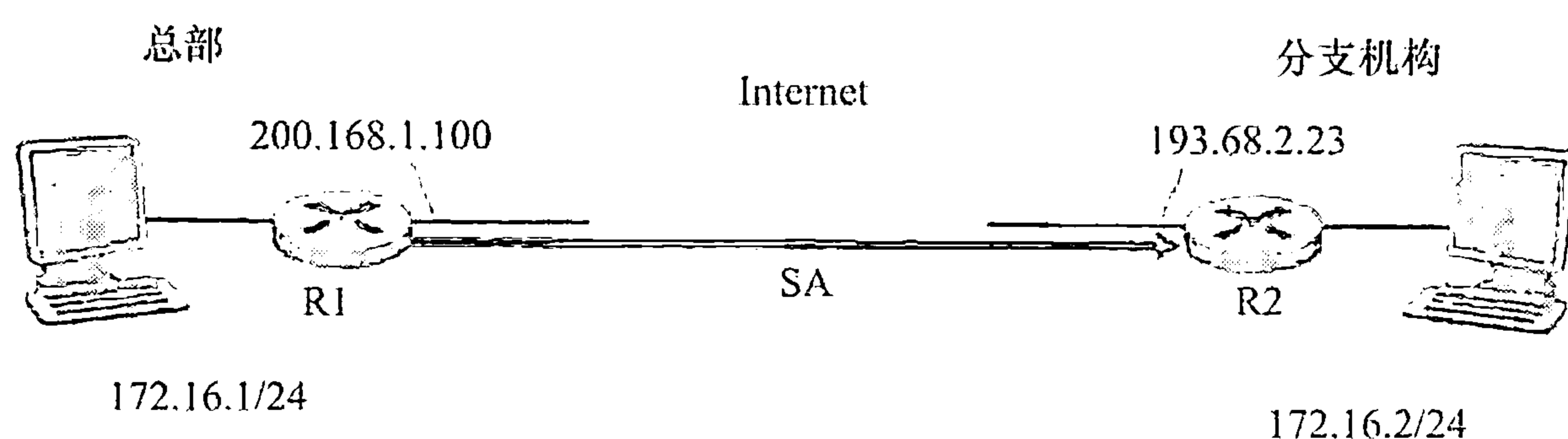


图 8-28 从 R1 到 R2 的安全关联

一、我们现在观察 SA 的“内部”。为了使讨论明确和具体，我们在图 8-28 中的一个从路由器 R1 到路由器 R2 的 SA 场景下进行观察。（你能够认为路由器 R1 是图 8-27 中的总部网关路由器，而路由器 R2 是图 8-27 中的分支机构网关路由器。）路由器 R1 将维护有关该 SA 的状态信息，这将包括：

- SA 的 32 比特的标识符，称为安全参数索引（Security Parameter Index, SPI）。
- SA 的初始接口（在此例中为 200.168.1.100）和 SA 的目的接口（在此例中为 193.68.2.23）。
- 将使用的加密类型（例如，具有 CBC 的 3DES）。
- 加密密钥。
- 完整性检查的类型（例如，具有 MD5 的 HMAC）。
- 鉴别密钥。

无论何时路由器 R1 需要构建一个 IPsec 数据报经过这个 SA 转发，它访问该状态信息以决定它应当如何鉴别和加密该数据报。类似地，路由器 R2 将维护对此 SA 的相同的状态信息，并将使用该信息鉴别和加密任何从该 SA 到达的 IPsec 数据报。

一个 IPsec 实体（路由器或主机）经常维护许多 SA 的状态信息。例如，在图 8-27 中具有 n 个销售员的 VPN 例子中，总部网关路由器维护 $(2 + 2n)$ 个 SA 的状态信息。一个 IPsec 实体在它的安全关联数据库（Security Association Database, SAD）中存储其所有 SA 的状态信息，SAD 是实体操作系统内核中的一个数据结构。

8.7.4 IPsec 数据报

在描述了 SA 后，我们现在能够描述实际的 IPsec 数据报了。IPsec 有两种不同的分组形式，一种用于所谓隧道模式（tunnel mode），另一种用于所谓运输模式（transport mode）。更为适合 VPN 的隧道模式比运输模式部署得更为广泛。为了进一步讲清 IPsec 和避免许多难题，我们因此专门关注隧道模式。一旦已经牢牢地掌握了隧道模式，应当能够容易地自学运输模式。

IPsec 数据报的分组格式显示在图 8-29 中。你也许认为分组格式是枯燥乏味的，但我们将很快看到 IPsec 数据报实际上尝起来像美式墨西哥风味（Tex-Mex）美食！我们考察图 8-28 的场景中的 IPsec 字段。假设路由器 R1 接收到一个来自主机 172.16.1.17（在总部网络中）的普通 IPv4 数据报，该分组的目的地是主机 172.16.2.48（在分支机构网络中）。路由器 R1 使用下列方法将这个“普通 IPv4 数据报”转换成一个 IPsec 数据报：

- 在初始 IPv4 数据报（它包括初始首部字段！）后面附上一个“ESP 尾部”字段。

- 使用算法和由 SA 规定的密钥加密该结果。
- 在这个加密量的前面附加上一个称为“ESP 首部”的字段；得到的包称为“enchilada”（以辣椒调味的一种墨西哥菜。——译者注）。
- 使用算法和由 SA 规定的密钥生成一个覆盖整个 enchilada 的鉴别 MAC。
- 该 MAC 附加到 enchilada 的后面形成载荷。
- 最后，生成一个具有所有经典 IPv4 首部字段（通常共 20 字节长）的全新 IP 首部，该新首部附加到载荷之前。

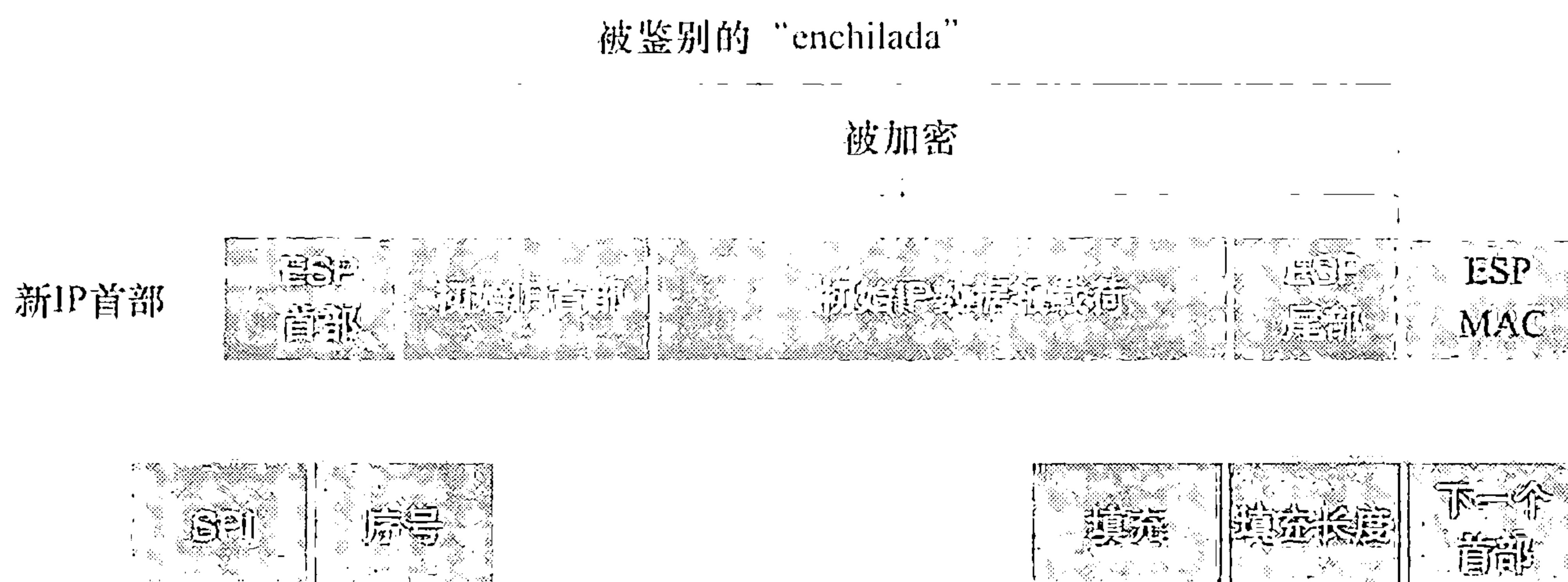


图 8-29 IPsec 数据报格式

注意到得到的 IPsec 数据报是一个货真价实的 IPv4 数据报，它具有传统的 IPv4 首部字段后跟一个载荷。但在这个场合，该载荷包含一个 ESP 首部、初始 IP 数据报、一个 ESP 尾部和一个 ESP 鉴别字段（具有加密的初始数据报和 ESP 尾部）。初始的 IP 数据报具有源 IP 地址 172.16.1.17 和目的地址 172.16.2.48。因为 IPsec 数据报包括了该初始 IP 数据报，这些地址被包含和被加密作为 IPsec 分组负载的组成部分。但是在新 IP 首部中的源和目的地 IP 地址，即在 IPsec 数据报的最左侧首部又该如何处理呢？如你所猜测，它们被设置为位于隧道两个端点的源和目的地路由器接口，也就是 200.168.1.100 和 193.68.2.23。同时，这个新 IPv4 首部字段中的协议号不被设置为 TCP、UDP 或 SMTP，而是设置为 50，指示这是一个使用 ESP 协议的 IPsec 数据报。

在 R1 将 IPsec 数据报发送进公共因特网之后，它在到达 R2 之前将通过许多路由器。这些路由器中的每个将处理该数据报，就像它是一个普通数据报一样，即它们被完全忘记这样的事实：该数据报正在承载 IPsec 加密的数据。对于这些公共因特网路由器，因为在外面的首部中的目的 IP 地址是 R2，所以该数据报的最终目的地是 R2。

在考察了如何构造一个 IPsec 数据报的例子后，我们现在更仔细地观察 enchilada 的组成。我们看到在图 8-29 中的 ESP 尾部由三个字段组成：填充、填充长度和下一个首部。前面讲过块密码要求被加密的报文必须为块长度的整数倍。使用填充（由无意义的字节组成），使得当其加上初始数据报（连同填充长度字段和下一个首部字段）形成的“报文”是块的整数倍。填充长度字段指示接收实体插入的填充是多少（并且需要被删除）。下一个首部字段指示包含在载荷数据字段中数据的类型（例如 UDP）。载荷数据（通常是初始 IP 数据报）和 ESP 尾部级联起来并被加密。

附加到这个加密单元前面的是 ESP 首部，该首部以明文发送，它由两个字段组成：SPI 字段和序号字段。SPI 字段指示接收实体该数据报属于哪个 SA；接收实体则能够用该 SPI 索引其 SAD 以确定适当的鉴别/解密算法和密钥。序号字段用于防御重放攻击。

发送实体也附加一个鉴别 MAC。如前所述，发送实体跨越整个 enchilada（由 ESP 首部、初始 IP 数据报和 ESP 尾部组成，即具有加密的数据报和尾部）计算一个 MAC。前面讲过为了计算一个 MAC，发送方附加一个秘密 MAC 密钥到该 enchilada，进而计算该结果的一个固定长度散列。

当 R2 接收到 IPsec 数据报时，R2 看到该数据报的目的 IP 地址是 R2 自身。R2 因此处理该数据报。因为协议字段（位于 IP 首部最左侧）是 50，R2 明白应当对该数据报施加 IPsec ESP 处理。第一，针对 enchilada，R2 使用 SPI 以确定该数据报属于哪个 SA。第二，它计算该 enchilada 的 MAC 并且验证该 MAC 与在 ESP MAC 字段中的值一致。如果两者一致，它知道该 enchilada 来自 R1 并且未被篡改。第三，它检查序号字段以验证该数据报是新的（并且不是重放的数据报）。第四，它使用与 SA 关联的解密算法和密钥解密该加密单元。第五，它删除填充并抽取初始的普通 IP 报文。最后，它朝着其最终目的地将该初始数据报转发进分支机构网络。这个一种多么复杂的秘诀呀！还未曾有人声称准备并破解 enchilada 是一件容易的事！

实际上还有另一个重要的细微差别需要处理。它以下列问题为中心：当 R1 从位于总部网络中的一台主机收到一个（未加密的）数据报时，并且该数据报目的地为总部以外的某个目的 IP 地址，R2 怎样才能知道它应当将其转换为一个 IPsec 数据报呢？并且如果它由 IPsec 处理，R1 如何知道它应当使用（在其 SAD 中的许多 SA 中）哪个 SA 来构造这个 IPsec 数据报呢？该问题以如下方式解决。除了 SAD 外，IPsec 实体也维护另一个数据结构，它称为安全策略库（Security Policy Database，SPD）。该 SPD 指示哪些类型的数据报（作为源 IP 地址、目的 IP 地址和协议类型的函数）将被 IPsec 处理；并且对这些将被 IPsec 处理的数据报应当使用哪个 SA。从某种意义上讲，在 SPD 中的信息指示对于一个到达的数据报做“什么”；在 SAD 中的信息指示“怎样”去做。

IPsec 服务的小结

IPsec 究竟提供什么样的服务呢？我们从某攻击者 Trudy 的角度来考察这些服务，Trudy 是一个中间人，位于图 8-28 中 R1 和 R2 之间路径上的某处。假设通过这些讨论，Trudy 不知道 SA 所使用的鉴别和加密密钥。Trudy 能够做些什么和不能够做些什么呢？第一，Trudy 不能看到初始数据报。如果事实如此，不仅 Trudy 看不到在初始数据报中的数据，而且也看不到协议号、源 IP 地址和目的 IP 地址。对于经该 SA 发送的数据报，Trudy 仅知道该数据报源于 172.16.1.0/24 的某台主机以及目的地为 172.16.2.0/24 的某台主机。她不知道它是否携带 TCP、UDP 或 ICMP 数据；她不知道它是否携带了 HTTP、SMTP 或某些其他类型的应用程序数据。因此这种机密性比 SSL 范围更为宽广。第二，Trudy 试图用反转数据报的某些比特来篡改在 SA 中的某个数据报，当该篡改的数据报到达 R2 时，它将难以通过完整性核查（使用 MAC），再次挫败了 Trudy 的恶意尝试。第三，假设 Trudy 试图假冒 R1，生成一个源为 200.168.1.100 和目的地为 193.68.2.23 的 IPsec 数据报。Trudy 的攻击将是无效的，因为这个数据报将再次通不过在 R2 的完整性核查。最后，因为 IPsec 包含序号，Trudy 将不能够生成一个成功的重放攻击。总而言之，正如本节开始所言，IPsec 在任何通过网络层处理分组的设备对之间，提供了机密性、源鉴别、数据完整性和重放攻击防护。

8.7.5 IKE：IPsec 中的密钥管理

当某 VPN 具有少量的端点时（例如，图 8-28 中只有两台路由器），网络管理员能够

在该端点的 SAD 中人工键入 SA 信息（加密/鉴别算法和密钥及 SPI）。这样的“人工密钥法”对于一个大型 VPN 显然是不切实际的，因为大型 VPN 可能由成百甚至上千台 IPsec 路由器和主机组成。大型的、地理上分散的部署要求一个自动的机制来生成 SA。IPsec 使用因特网密钥交换（Internet Key Exchange, IKE）协议来从事这项工作，IKE 由 RFC 5996 定义。

IKE 与 SSL（参见 8.6 节）中的握手具有某些类似。每个 IPsec 实体具有一个证书，该证书包括了该实体的公开密钥。如同使用 SSL 一样，IKE 协议让两个实体交换证书，协商鉴别和加密算法，并安全地交换用于在 IPsec SA 中生成会话密钥的密钥材料。与 SSL 不同的是，IKE 应用两个阶段来执行这些任务。

我们来研究图 8-28 中两台路由器 R1 和 R2 场景下的这两个阶段。第一个阶段由 R1 和 R2 之间报文对的两次交换组成：

- 在报文的第一次交换期间，两侧使用 Diffie-Hellman（参见课后习题）在路由器之间生成一个双向的 IKE SA。为了防止混淆，这个双向 IKE SA 完全不同于 8.6.3 节和 8.6.4 节所讨论的 IPsec SA。该 IKE SA 在这两台路由器之间提供了一个鉴别的和加密的信道。在首个报文对交换期间，创建用于 IKE SA 的加密和鉴别的密钥。还创建了将用于计算后期在阶段 2 使用的 IPsec SA 密钥的一个主密钥。观察在第一步骤期间，没有使用 RSA 公钥和私钥。特别是，R1 或 R2 都没有通过用它们的私钥对报文签字而泄露其身份。
- 在报文的第二次交换期间，两侧通过对其报文签名而透漏了它们的身份。然而，这些身份并未透漏给被动的嗅探者，因为这些报文是经过安全的 IKE SA 信道发送的。同时在这个阶段期间，两侧协商由 IPsec SA 应用的 IPsec 加密和鉴别算法。

在 IKE 的第二个阶段，两侧生成在每个方向的一个 SA。在阶段 2 结束时，对这两个 SA 的每一侧都建立了加密和鉴别会话密钥。然后这两侧都能使用 SA 来发送安全的数据报，如同 8.7.3 节和 8.7.4 节描述的那样。在 IKE 中有两个阶段的基本动机是计算成本，即因为第二阶段并不涉及任何公钥密码，IKE 能够以相对低的计算成本在两个 IPsec 实体之间生成大量 SA。

8.8 使无线 LAN 安全

在无线网络中安全性是特别重要的关注因素，因为这时携带数据帧的无线电波可以传播到远离包含无线基站和主机的建筑物以外的地方。在本节中，我们简要介绍了无线安全性。对于更为深入地探讨，参见由 Edney 和 Arbaugh 撰写的可读性很强的书 [Edney 2003]。

在 802.11 中的安全性问题受到了技术界和媒体界的极大关注。在进行大量讨论的同时，一个几乎没有争论的事实是，看起来被广泛认同的初始 802.11 规范具有一些严重的安全性缺陷。现在的确能够下载利用这些漏洞的公共域软件，使得那些使用该普通 802.11 安全性机制的用户面对安全性攻击，就像根本没有使用安全性措施的网络用户一样，门户洞开。

在下面一节中，我们讨论最初在 802.11 规范中标准化的安全性机制，该规范统称为有线等效保密（Wired Equivalent Privacy, WEP）。顾名思义，WEP 意欲提供类似于在有线网络中的安全性水平。接下来我们将讨论 WEP 中的安全性漏洞并讨论 802.11i 标准，后者是在 2004 年采纳的 802.11 的本质性更为安全的版本。

8.8.1 有线等效保密

IEEE 802.11 的 WEP 协议设计于 1999 年，为在主机和无线接入点（即基站）之间提供鉴别和数据的加密。WEP 并没有指定密钥管理算法，因此它假定主机和无线接入点之间通过带外方式就密钥达成了某种一致。鉴别以下列方式进行：

- 1) 无线主机通过接入点请求鉴别。
- 2) 接入点以一个 128 字节的不重数值响应该鉴别请求。
- 3) 无线主机用它与这个接入点共享的密钥加密这个不重数值。
- 4) 接入点解密主机加密的不重数值。

如果解密所得不重数值与初始发给主机的值相同，则这个接入点鉴别了该主机。

图 8-30 阐述了 WEP 数据加密算法。假定主机和接入点都知道一个秘密的 40 比特对称密钥 K_s 。此外，一个 24 比特的初始向量（IV）附加到这个 40 比特的密钥后面，产生用于加密单个帧的一个 64 比特密钥。每一个帧所使用的 IV 都不同，所以每一帧都由不同的 64 比特密钥加密。加密以如下方式进行。首先为每个数据载荷计算一个 4 字节的 CRC 值（见 5.2 节）。然后用 RC4 流密码加密该载荷和该 4 字节 CRC。我们这里不涉及 RC4 的细节（细节参见 [Schneier 1995] 和 [Edney 2003]）。就我们的目的而言，知道下列事实即可：对于密钥值（此时为 64 比特（ K_s 、IV）密钥），RC4 算法产生一个密钥值的流为 k_1^{IV} , k_2^{IV} , k_3^{IV} , ..., 这些密码值用于加密一帧中的数据 and CRC 值。出于实用的目的，我们可以认为每次对一个字节执行这些操作。通过把数据的第 i 字节 d_i 和由（ K_s 、IV）对生成的密钥值流中的第 i 个密钥 k_i^{IV} 执行异或操作进行加密，以产生密文的第 i 字节 c_i ：

$$c_i = d_i \oplus k_i^{IV}$$

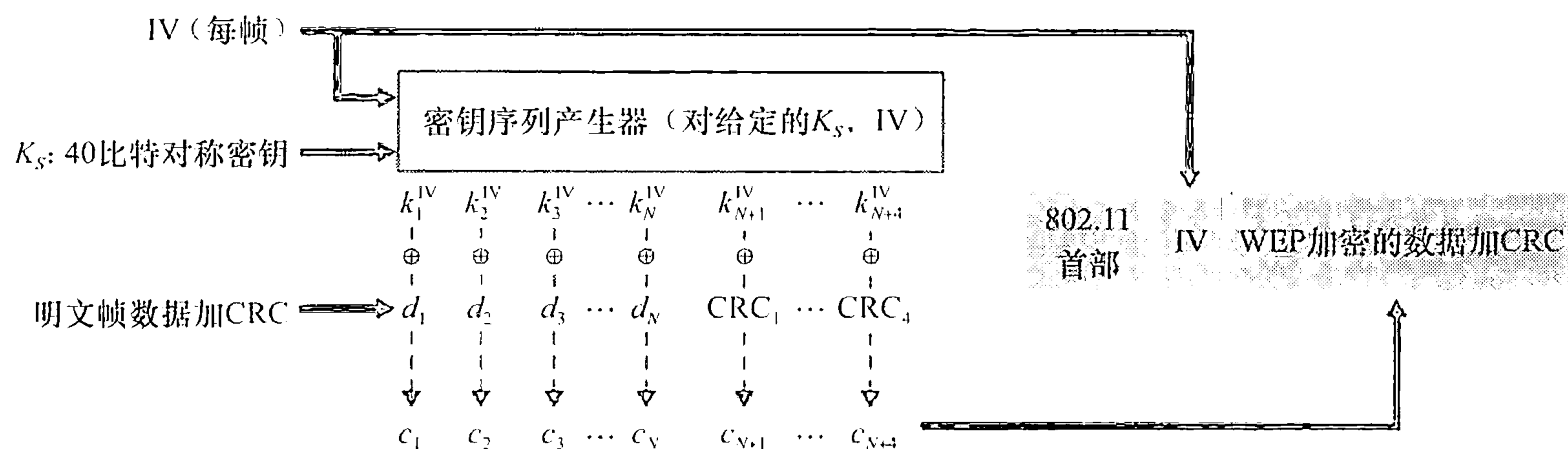


图 8-30 802.11 WEP 协议

如图 8-30 中所示，该 IV 值逐帧而变化，以明文形式出现在每一个 WEP 加密的 802.11 帧的首部中。接收方取它与发送方共享的秘密 40 比特对称密钥，添加上该 IV，并使用形成的 64 比特的密钥（它与发送方执行加密所用的密钥相同）来解密这个帧。

$$d_i = c_i \oplus k_i^{IV}$$

正确使用 RC4 算法要求同一个 64 比特密钥决不能使用超过 1 次。前面讲过 WEP 密钥是每一帧变换一次。对于某给定的 K_s （如果它有变化的话也是很少的），这意味着只有 2^{24} 个不同的密钥可用。如果随机选择这些密钥的话，我们能够看到 [Walker 2000; Edney 2003]，则仅在处理 12 000 帧之后就选中相同的 IV 值（从而使用相同的 64 比特密钥）的概率超过 99%。在 1KB 帧长和 11Mbps 数据传输率的情况下，传输 12 000 帧仅需几秒的时间。

此外，由于 IV 值在该帧中以明文形式传输，窃听者就会发现何时使用了一个重复的 IV 值。

为理解重复使用一个密钥可能出现的几个问题之一，考虑下面的选择明文攻击的情况，仍以 Trudy 对 Alice 进行攻击为例。假定 Trudy（可能使用 IP 哄骗）向 Alice 发出一个请求（例如，一个 HTTP 或 FTP 请求），要求 Alice 传输内容已知的文件 $d_1, d_2, d_3, d_4, \dots$ ，Trudy 也观察到 Alice 发送的已加密数据 $c_1, c_2, c_3, c_4, \dots$ ，由于 $d_i = c_i \oplus k_i^{\text{IV}}$ ，如果在这个等式两边同时异或 c_i ，可得到：

$$d_i \oplus c_i = k_i^{\text{IV}}$$

根据这个关系，Trudy 就可以使用已知的 d_i 和 c_i 值计算出 k_i^{IV} 。下一次 Trudy 看到使用同一 IV 值时，她将知道密钥流为 $k_1^{\text{IV}}, k_2^{\text{IV}}, k_3^{\text{IV}}, \dots$ ，并可使用这些密钥解密报文。

对于 WEP 还有其他几个值得关注的安全性问题。[Fluhrer 2001] 描述了一种攻击方法，即当选择某些弱密钥时在 RC4 中暴露出的一种已知弱点。[Stubblefield 2002] 讨论了实现和开发这种攻击的有效方法。对 WEP 的另一种关注与在图 8-30 中显示并在 802.11 帧中传输的用以检测载荷中改变的比特的 CRC 比特有关。然而，攻击者在改变加密内容（例如用乱七八糟的东西替代初始的加密数据）后，对这些被替换的东西计算出一个 CRC，并将该 CRC 放置在 WEP 帧中产生一个将被接收方接受的 802.11 帧。此时所需要的是诸如我们在 8.3 节中学习的报文完整性技术来检测内容篡改或替换。有关 WEP 安全性更多的细节，参见 [Edney 2003; Walker 2000; Weatherspoon 2000] 及其中的参考文献。

8.8.2 IEEE 802.11i

在 IEEE 802.11 于 1999 年发布后不久，就开始研发具有更强安全性机制的 802.11 的新型、改进版本。这个新标准被称为 802.11i，于 2004 年最终得到批准。如我们将看到的那样，虽然 WEP 提供了相对弱的加密、仅有单一方式执行鉴别并且没有密钥分发机制，但 IEEE 802.11i 却提供了强得多的加密形式、一种可扩展的鉴别机制集合以及一种密钥分发机制。下面我们概述一下 802.11i；[TechOnline 2012] 是一篇关于 802.11i 的优秀（流式音频）技术概述。

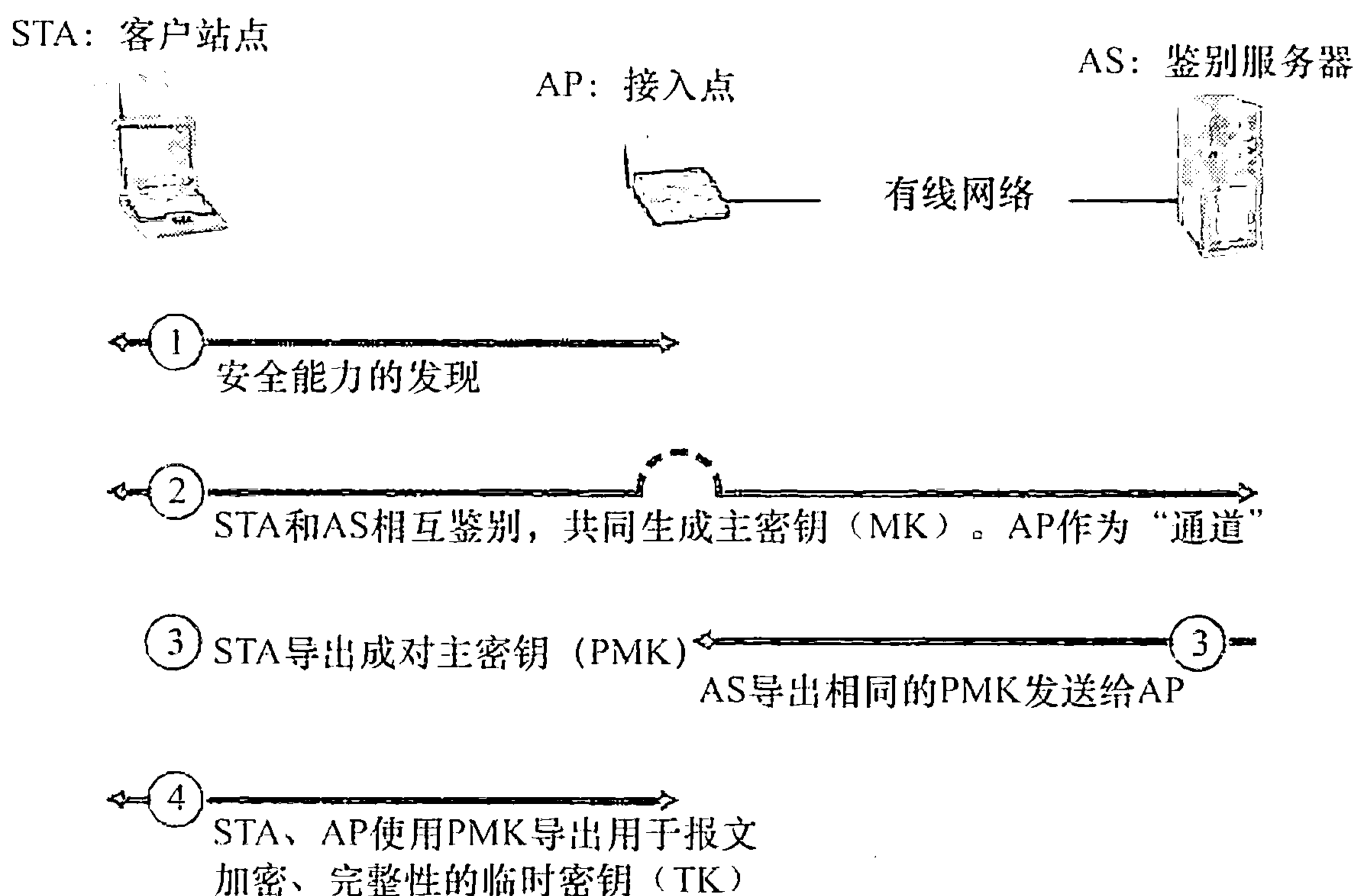


图 8-31 802.11i：运行的 4 个阶段

图 8-31 概述了 802.11i 的框架。除了无线客户和接入点外，802.11i 定义了一台鉴别服务器，AP 能够与它通信。鉴别服务器与 AP 的分离使得一台鉴别服务器服务于许多 AP，

集中在一台服务器中作出有关鉴别和接入（通常是敏感）的决定，降低了 AP 的成本和复杂性。802.11i 运行分为 4 个阶段：

1) 发现。在发现阶段，AP 通告它的存在以及它能够向无线客户结点提供的鉴别和加密形式。客户则请求它希望的特定鉴别和加密形式。尽管客户和 AP 已经交换了报文，但该客户还没有被鉴别，也还没有加密密钥，因此在该客户能够通过无线信道与任何远程主机通信之前，还需要进行几个其他步骤。

2) 相互鉴别和主密钥（MK）生成。鉴别发生在无线客户和鉴别服务器之间。在这个阶段，接入点基本是起中继的作用，在客户和鉴别服务器之间转发报文。可扩展鉴别协议（Extensible Authentication Protocol, EAP）[RFC 3748] 定义了客户和鉴别服务器之间交互时简单的请求/响应模式中使用的端到端报文格式。如图 8-32 中所示，EAP 报文使用 EAPoL（EAP over LAN, [IEEE 802.1x]）进行封装，并通过 802.11 无线链路发送。这些 EAP 报文在接入点拆封，然后再使用 RADIUS 协议重新封装，经 UDP/IP 传输到鉴别服务器。尽管 RADIUS 服务器和协议 [RFC 2865] 并不为 802.11i 所要求，但它们是 802.11i 的事实上的标准组件。最近标准化的 DIAMETER 协议 [RFC 3588] 很可能在不久的将来替代 RADIUS。

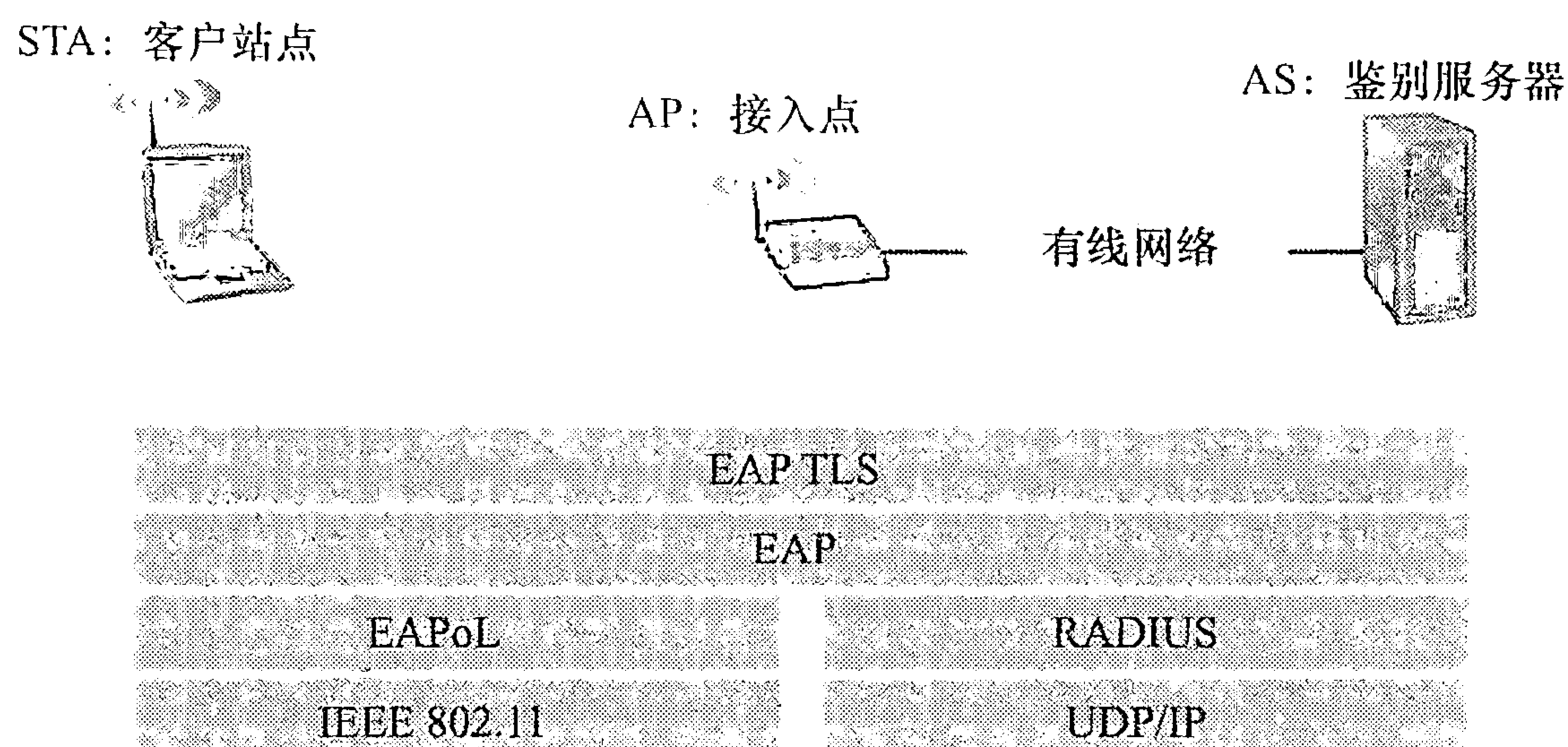


图 8-32 EAP 是一个端到端协议。EAP 报文使用 EAPoL（运行在客户和接入点之间的无线链路上）封装，并使用 RADIUS（运行在接入点和鉴别服务器之间的 UDP/IP 上）

使用 EAP，鉴别服务器能够选择若干方式中的一种来执行鉴别。802.11i 虽未强制一种特殊的鉴别方法，但经常使用 EAP-TLS 鉴别方案 [RFC 5216]。EAP-TLS 使用类似于我们在 8.3 节中研究的公钥技术（包括不重数加密和报文摘要），以允许客户和鉴别服务器彼此相互鉴别，并导出为双方所知的一个主密钥。

3) 成对主密钥（Pairwise Master Key, PMK）生成。MK 是一个仅为客户和鉴别服务器所知的共享密钥，它们都使用 MK 来生成一个次密钥，即成对主密钥（PMK）。鉴别服务器则向 AP 发送该 PMK。这正是我们所希望达到的目的！客户和 AP 现在具有一个共享的密钥（前面讲过在 WEP 中根本不涉及密钥分发的问题），并彼此相互鉴别。它们此时已经快要能发挥效用了。

4) 临时密钥（Temporal Key, TK）生成。使用 PMK，无线客户和 AP 现在能够生成附加的、将用于通信的密钥。其中的关键是临时密钥，TK 将被用于执行经无线链路向任意远程主机发送数据的链路级的加密。

802.11i 提供了几种加密形式，其中包括基于 AES 的加密方案和 WEP 加密的强化版本。

8.9 运行安全性：防火墙和入侵检测系统

遍及本章我们已经看出，因特网不是一个很安全的地方，即有坏家伙出没，从事着各种各样的破坏活动。给定因特网的不利性质，我们现在考虑一个机构网络和管理它的网络管理员。从网络管理员的角度看，世界可以很明显地分为两个阵营：一部分是好人，他们属于本机构网络，可以用相对不受限制的方式访问该机构网络中的资源；另一部分是坏家伙，他们是其他一些人，访问网络资源时必须经过仔细审查。在许多机构中，从中世纪的城堡到现代公司的建筑物，都有单一的出口/入口，无论好人坏人出入该机构，都需要进行安全检查。在一个城堡中，可以在吊桥的一端的门口执行安全检查；在公司大厦中，这些工作可在安全台完成。在计算机网络中，当通信流量进入/离开网络时要执行安全检查、做记录、丢弃或转发，这些工作都由被称为防火墙、入侵检测系统（IDS）和入侵防止系统（IPS）的运行设备来完成。

8.9.1 防火墙

防火墙（firewall）是一个硬件和软件的结合体，它将一个机构的内部网络与整个因特网隔离开，允许一些数据分组通过而阻止另一些分组通过。防火墙允许网络管理员控制外部和被管理网络内部资源之间的访问，这种控制是通过管理流入和流出这些资源的流量实现的。防火墙具有3个目标：

- 从外部到内部和从内部到外部的所有流量都通过防火墙。图8-33显示了一个防火墙，位于被管理网络和因特网其余部分之间的边界处。虽然许多大型机构可使用多级防火墙或分布式防火墙 [Skoudis 2006]，但在对该网络的单一接入点处设置一个防火墙，如图8-33中所示，这使得管理和施加安全访问策略更为容易。
- 仅被授权的流量（由本地安全策略定义）允许通过。随着进入和离开机构网络的所有流量流经防火墙，该防火墙能够限制对授权流量的访问。
- 防火墙自身免于渗透。防火墙自身是一种与网络连接的设备，如果设计或安装不当，将可能危及安全，在这种情况下它仅提供了一种安全的假象（这比根本没有防火墙更糟糕！）。

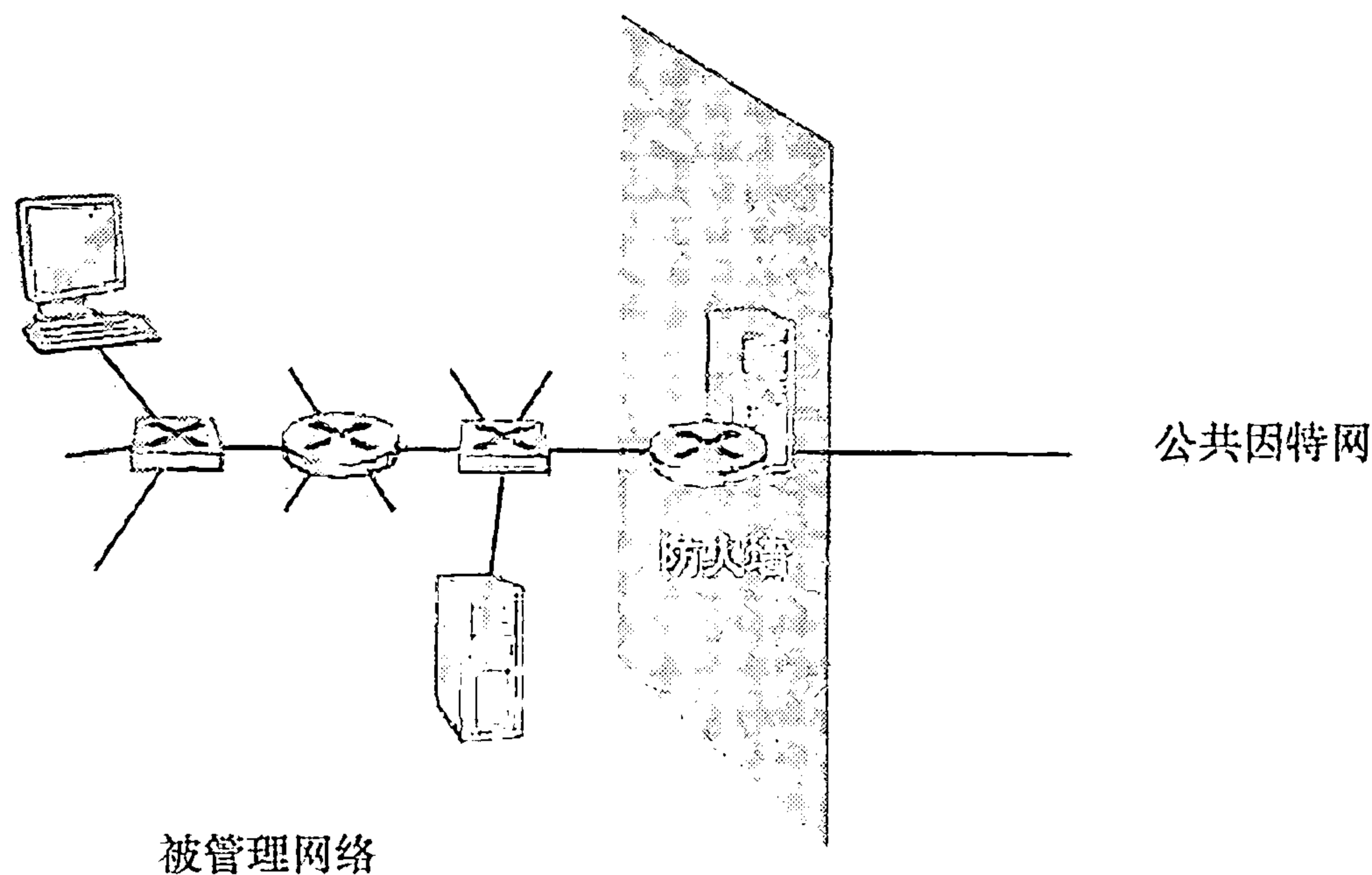


图 8-33 在被管理网络和外部之间放置防火墙

Cisco 和 Check Point 是当今两个领先的防火墙厂商。你也能够容易地从 Linux 套件使用 iptables（通常与 Linux 装在一起的公共域软件）产生一个防火墙（分组过滤器）。

防火墙能够分为 3 类：传统分组过滤器（traditional packet filter）、状态过滤器（stateful filter）和应用程序网关（application gateway）。在下面小节中，我们将依次学习它们。

1. 传统的分组过滤器

如图 8-33 所示，一个机构通常都有一个将其内部网络与其 ISP（并因此与更大的公共因特网相连）相连的网关路由器。所有离开和进入内部网络的流量都要经过这个路由器，而这个路由器正是分组过滤（packet filtering）出现的地方。分组过滤器独立地检查每个数据报，然后基于管理员特定的规则决定该数据报应当允许通过还是应当丢弃。过滤决定通常基于下列因素：

- IP 源或目的地址。
- 在 IP 数据报中的协议类型字段：TCP、UDP、ICMP、OSPF 等。
- TCP 或 UDP 的源和目的端口。
- TCP 标志比特：SYN、ACK 等。
- ICMP 报文类型。
- 数据报离开和进入网络的不同规则。
- 对不同路由器接口的不同规则。

网络管理员基于机构的策略配置防火墙。该策略可以考虑用户生产率和带宽使用以及对一个机构的安全性关注。表 8-5 列出了一个机构可能具有的若干可能的策略，以及它们是如何用一个分组过滤器来处理分组的。例如，如果该机构除了允许访问它的公共 Web 服务器外不希望任何入 TCP 连接的话，那么它能够阻挡所有的入 TCP SYN 报文段，但具有目的地端口 80 的 TCP SYN 报文段除外，并且该目的 IP 地址对应于该 Web 服务器。如果该机构不希望它的用户用因特网无线电应用独占访问带宽，那么它能够阻挡所有非关键性 UDP 流量（因为因特网无线电经常是通过 UDP 发送的）。如果该机构不希望它的内部网络被外部绘制结构图（被跟踪路由），那么它能够阻挡所有 ICMP TTL 过期的报文离开该机构的网络。

表 8-5 对于 Web 服务器在 130. 207. 244. 203 的某机构网络 130. 207/16，其策略和对应的过滤规则

策略	防火墙设置
无外部 Web 访问	丢弃所有到任何 IP 地址、端口 80 的出分组
无人 TCP 连接，但那些只访问机构公共 Web 服务器的分组除外	丢弃所有到除 130. 207. 244. 203、端口 80 外的任何 IP 地址的入 TCP SYN 分组
防止 Web 无线电占据可用带宽	丢弃所有入 UDP 分组，但 DNS 分组除外
防止你的网络被用于一个 smurf DoS 攻击	丢弃所有去往某“广播”地址（例如 130. 207. 255. 255）的 ICMP ping 分组
防止你的网络被跟踪路由	丢弃所有出 ICMP TTL 过期流量

一条过滤策略能够基于地址和端口号的结合。例如，一台过滤路由器能够转发所有 Telnet 数据报（那些具有端口号 23 的数据报），但那些包括在一个特定的 IP 地址列表中的去往和来自的地址除外。这些策略允许在许可列表上的地址进行 Telnet 连接。不幸的是，基于外部地址的策略无法对其源地址被哄骗的数据报提供保护。

过滤也可根据 TCP ACK 比特是否设置来进行。如果一个机构要使内部客户连接到外部服务器，却要防止外部客户连接到内部服务器，这个技巧很有效。3.5 节讲过，在每个 TCP 连接中第一个报文段的 ACK 比特都设为 0，而连接中的所有其他报文段的 ACK 比特都设为 1。因此，如果一个机构要阻止外部客户发起到内部服务器的连接，就只需直接过滤进入的所有 ACK 比特设为 0 的报文段。这个策略去除了所有从外部发起的所有 TCP 连接，但是允许内部发起 TCP 连接。

在路由器中使用访问控制列表实现防火墙规则，每个路由器接口有它自己的列表。表 8-6 中显示了对于某机构 222.22/16 的访问控制列表的例子。该访问控制列表适用于将路由器与机构外部 ISP 连接的某个接口。这些规则被应用到通过该接口自上而下传递的每个数据报。前两条规则一起允许内部用户在 Web 上冲浪：第一条规则允许任何具有目的端口 80 的 TCP 分组离开该机构网络；第二条规则允许任何具有源端口 80 且 ACK 比特置位的 TCP 分组进入该机构网络。注意到如果一个外部源试图与一台内部主机建立一条 TCP 连接，该连接将被阻挡，即使该源或目的端口为 80。接下来的两条规则一起允许 DNS 分组进入和离开该机构网络。总而言之，这种限制性相当强的访问控制列表阻挡所有流量，但由该机构内发起的 Web 流量和 DNS 流量除外。[CERT Filtering 2012] 提供了一个推荐的端口/协议分组过滤的列表，以避免在现有网络应用中的一些周知的安全性漏洞。

表 8-6 用于某路由器接口的访问控制列表

动作	源地址	目的地址	协议	源端口	目的端口	标志比特
允许	222.22/16	222.22/16 的外部	TCP	>1023	80	任意
允许	222.22/16 的外部	222.22/16	TCP	80	>1023	ACK
允许	222.22/16	222.22/16 的外部	UDP	>1023	53	—
允许	222.22/16 的外部	222.22/16	UDP	53	>1023	—
拒绝	全部	全部	全部	全部	全部	全部

2. 状态分组过滤器

在传统的分组过滤器中，根据每个分组分离地作出过滤决定。状态过滤器实际地跟踪 TCP 连接，并使用这种知识作出过滤决定。

为了理解状态过滤器，我们来重新审视表 8-6 中的访问控制列表。尽管限制性相当强，表 8-6 中的访问控制列表仍然允许来自外部的 ACK = 1 且源端口为 80 的任何分组到达，通过该过滤器。这样的分组能够被试图用异常分组来崩溃内部系统、执行拒绝服务攻击或绘制内部网络的攻击者使用。幼稚的解决方案是也阻挡 TCP ACK 分组，但是这样的方法将妨碍机构内部的用户在 Web 上冲浪。

状态过滤器通过用一张连接表来跟踪所有进行中的 TCP 连接来解决这个问题。这种方法是可能的：因为防火墙能够通过观察三次握手（SYN、SYNACK 和 ACK）来观察一条新连接的开始；而且当它看到该连接的一个 FIN 分组时，它能够观察该连接的结束。当防火墙经过比如说 60 秒还没有看到该连接的任何活动性，它也能够（保守地）假设该连接结束了。某防火墙的一张连接表例子显示在表 8-7 中。这张连接表指示了当前有 3 条进行中的 TCP 连接，所有的连接都是从该机构内部发起的。此外，该状态过滤器在它的访问控制列表中包括了一个新栏，即“核对连接”，如表 8-8 中所示。注意到表 8-8 与表 8-6 中的访问控制列表相同，只是此时它指示应当核对其中两条规则所对应的连接。

表 8-7 用于状态过滤器的连接表

源地址	目的地址	源端口	目的端口
222. 22. 1. 7	37. 96. 87. 123	12699	80
222. 22. 93. 2	199. 1. 205. 23	37654	80
222. 22. 65. 143	203. 77. 240. 43	48712	80

表 8-8 用于状态过滤器的访问控制列表

动作	源地址	目的地址	协议	源端口	目的端口	标志比特	核对连接
允许	222. 22/16	222. 22/16 的外部	TCP	> 1023	80	任意	
允许	222. 22/16 的外部	222. 22/16	TCP	80	> 1023	ACK	X
允许	222. 22/16	222. 22/16 的外部	UDP	> 1023	53	—	
允许	222. 22/16 的外部	222. 22/16	UDP	53	> 1023	—	X
拒绝	全部	全部	全部	全部	全部	全部	

我们浏览某些例子来看看连接表和扩展的访问控制列表是如何联手工作的。假设一个攻击者通过发送一个具有 TCP 源端口 80 和 ACK 标志置位的数据报，试图向机构网络中发送一个异常分组。进一步假设该分组具有源端口号 12543 和源 IP 地址 150. 23. 23. 155。当这个分组到防火墙时，防火墙核对表 8-8 中的访问控制列表，该表指出在允许该分组进入机构网络之前还必须核对连接表。该防火墙正确地核对了连接表，发现这个分组不是某进行中的 TCP 连接的一部分，从而拒绝了该分组。举第二个例子，假设一个内部的用户要在外部 Web 站点冲浪。因为该用户首先发送了一个 TCP SYN 报文段，所以该用户的 TCP 连接在连接表中有了记录。当 Web 服务器发送回分组（ACK 比特进行了必要的设置），该防火墙核对了连接表并明白一条对应的连接在进行中。防火墙因此将让这些分组通过，从而不会干扰内部用户的 Web 冲浪活动。

3. 应用程序网关

在上面的例子中，我们已经看到了分组级过滤使得一个机构可以根据 IP 的内容和 TCP/UDP 首部（包括 IP 地址、端口号和 ACK 比特）执行粗粒度过滤。但是如果一个机构仅为一个内部用户的受限集合（与 IP 地址情况正相反）提供 Telnet 服务该怎样做呢？如果该机构要这些特权用户在允许创建向外部的 Telnet 会话之前首先鉴别他们自己该怎样做呢？这些任务都超出了传统过滤器和状态过滤器的能力。的确，有关内部用户的身份信息是应用层数据，并不包括在 IP/TCP/UDP 首部中。

为了得到更高水平的安全性，防火墙必须把分组过滤器和应用程序网关结合起来。应用程序网关还除了看 IP/TCP/UDP 首部外，还基于应用数据来做策略决定。一个应用程序网关（application gateway）是一个应用程序特定的服务器，所有应用程序数据（入和出的）都必须通过它。多个应用程序网关可以在同一主机上运行，但是每一个网关都有自己的进程的单独服务器。

为了更深入地了解应用程序网关，我们来设计一个防火墙，它只允许内部客户的受限集合向外 Telnet，不允许任何外部客户向内 Telnet。这一策略可通过将分组过滤（在一台路由器上）和一个 Telnet 应用程序网关结合起来实现，如图 8-34 所示。路由器的过滤器配置为阻塞所有 Telnet 连接，但从该应用程序网关 IP 地址发起的连接除外。这样的过滤器配置迫使所有向外的 Telnet 连接都通过应用程序网关。现在考虑一个要向外 Telnet 的

内部用户。这个用户必须首先和应用程序网关建立一个 Telnet 会话。在网关（网关监听进入的 Telnet 会话）上一直运行的应用程序提示用户输入用户 ID 和口令。当这个用户提供这些信息时，应用程序网关检查这个用户是否得到许可向外 Telnet。如果没有，网关则中止这个内部用户向该网关发起的 Telnet 连接。如果该用户得到许可，则这个网关：①提示用户输入它所要连接的外部主机的主机名；②在这个网关和某外部主机之间建立一个 Telnet 会话；③将从这个用户到达的所有数据中继到该外部主机，并且把来自这个外部主机的所有数据都中继给这个用户。所以，该 Telnet 应用程序网关不仅执行用户授权，而且同时充当一个 Telnet 服务器和一个 Telnet 客户，在这个用户和该远程 Telnet 服务器之间中继信息。注意到过滤器因为该网关发起向外部的 Telnet 连接，将允许执行步骤②。

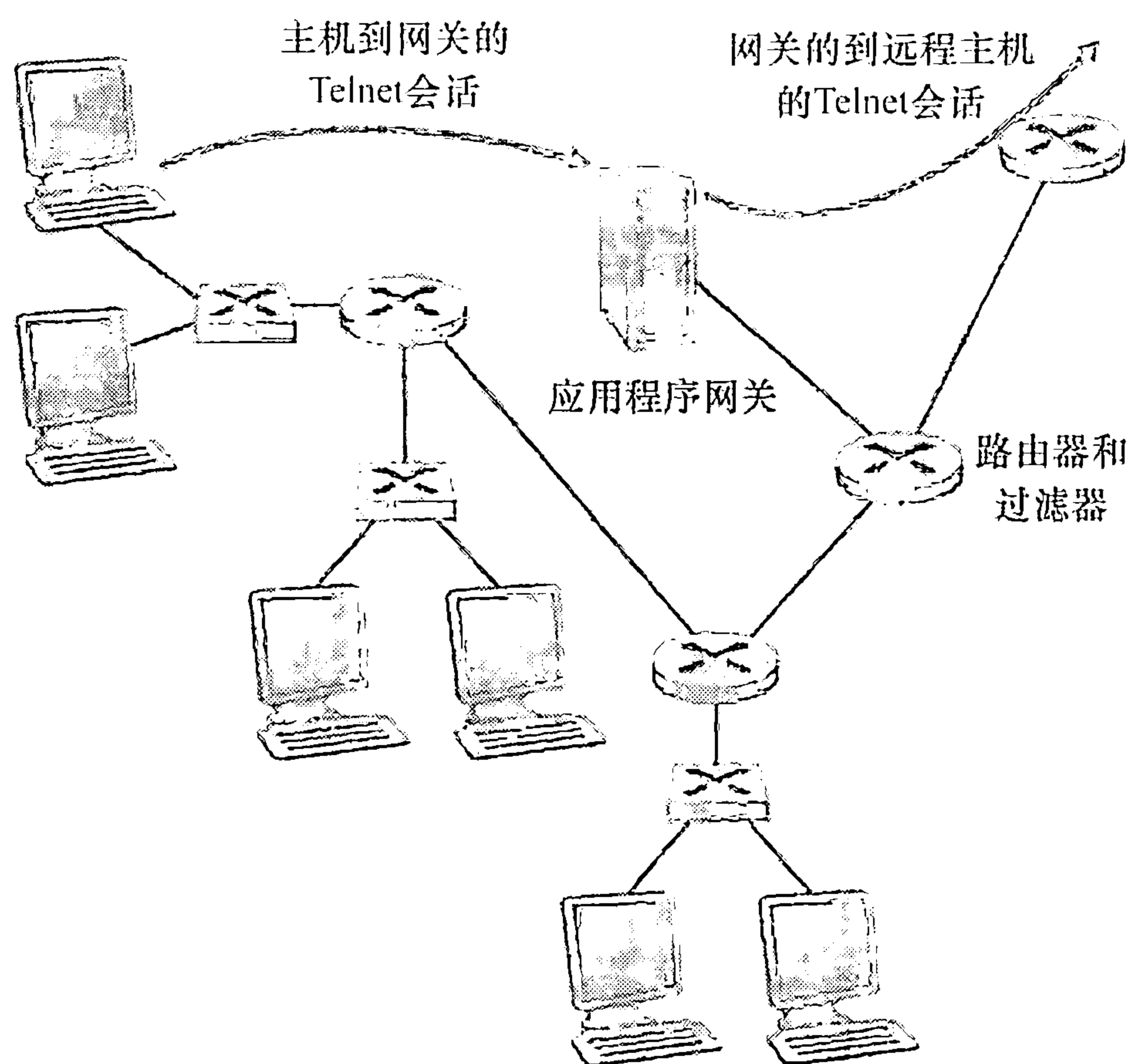


图 8-34 由应用程序网关和过滤器组成的防火墙

历史事件

匿名与隐私

假定你要访问一个有争议的 Web 网站（例如某政治活动家的网站），并且你：①不想向该 Web 网站透漏你的 IP 地址；②不想要你的本地 ISP（它可能是你住家或办公室的 ISP）知道你正在访问该站点；③不想要你的本地 ISP 看到你正在与该站点交换的数据。如果你使用传统的方法直接与该 Web 站点连接而没有任何加密，你无法实现这三个诉求。即使你使用 SSL，你也无法实现前两个诉求：你的源 IP 地址呈现在你发送给 Web 网站的每个数据报中；你发送的每个分组的目的地址能够容易地被你本地 ISP 嗅探到。

为了获得隐私和匿名，你能够使用如图 8-35 所示的一种可信代理服务器和 SSL 的组合。利用这种方法，你首先与可信代理建立一条 SSL 连接。然后你在该 SSL 连接中向所希望站点的网页发送一个 HTTP 请求。当代理接收到该 SSL 加密的 HTTP 请求，它解密请求并向 Web 站点转发该明文 HTTP 请求。接下来 Web 站点响应该代理，该代理经

过 SSL 再向你转发该响应。因为该 Web 站点仅看到代理的 IP 地址，并非你的客户 IP 地址，你的确获得了对该 Web 站点的匿名访问。并且因为你和代理之间的所有流量均被加密，你的本地 ISP 无法通过对你访问的站点做日志和记录你交换的数据来侵犯你的隐私。今天许多公司（例如 proxify.com）提供了这种代理服务。

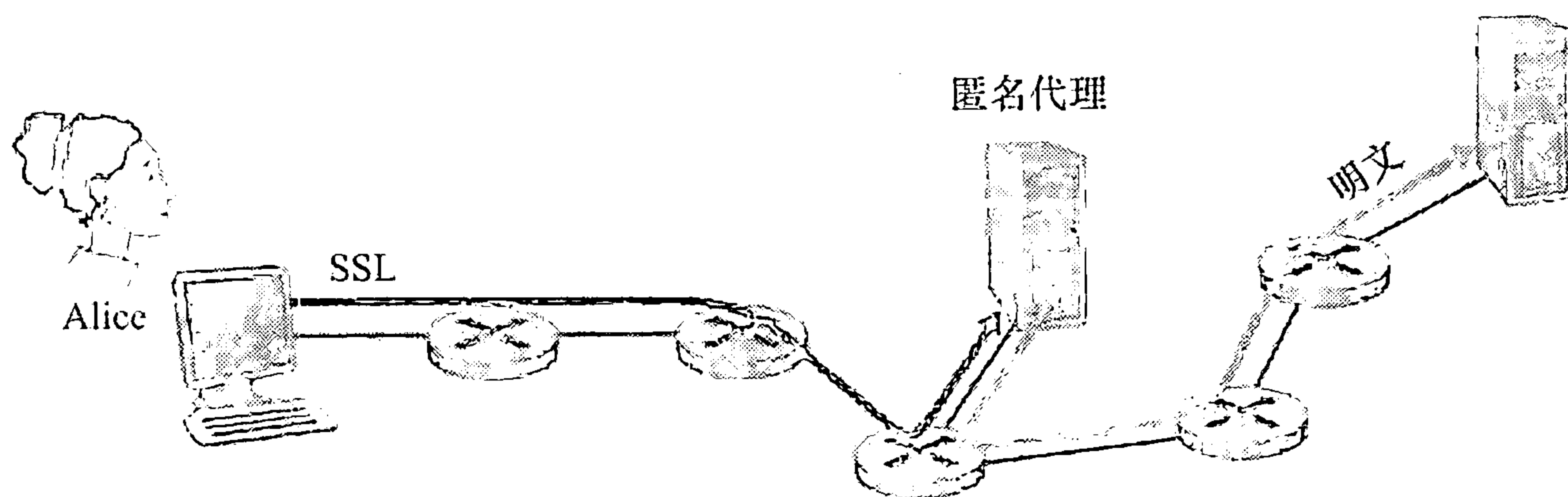


图 8-35 利用代理提供匿名和隐私

当然，在这个解决方案中，你的代理知道一切：它知道你的 IP 地址和你正在冲浪的站点的 IP 地址；并且它能够看到你与该 Web 站点之间以明文形式交换的所有流量。因此，这种解决方案的好坏取决于该代理的可信度。由 TOR 匿名和隐私服务所采用的一种更为健壮的方法是，让你的流量路由通过一系列“不串通”的代理服务器 [TOR 2012]。特别是，TOR 允许独立的个体向其代理池贡献代理。当某用户使用 TOR 与一个服务器连接，TOR 随机地（从它的代理池）选择一条三个代理构成的链，并通过该链在客户和服务器之间路由所有流量。以这种方式，假设这些代理并不串通，无人知道在你的 IP 地址和目标 Web 站点之间发生的通信。此外，尽管在最后的代理和服务器之间发送明文，但这个最后代理并不知道哪个 IP 地址正在发送和接收明文。

内部网络通常有多个应用程序网关，例如 Telnet、HTTP、FTP 和电子邮件网关。事实上，一个机构的邮件服务器（见 2.4 节）和 Web 高速缓存都是应用程序网关。

应用程序网关也有其缺陷。首先，每一个应用程序都需要一个不同的应用程序网关。第二，因为所有数据都由网关转发，付出的性能负担较重。当多个用户或应用程序使用同一个网关计算机时，这成为特别值得关注的问题。最后，当用户发起一个请求时，客户软件必须知道如何联系这个网关，并且必须告诉应用程序网关如何连接到哪个外部服务器。

8.9.2 入侵检测系统

我们刚刚看到，当决定让哪个分组通过防火墙时，分组过滤器（传统的和状态的）检查 IP、TCP、UDP 和 ICMP 首部字段。然而，为了检测多种攻击类型，我们需要执行深度分组检查（deep packet inspection），即查看首部字段以外部分，深入查看分组携带的实际应用数据。如我们在 8.9.1 节所见，应用程序网关经常做深度分组检查。而一个应用程序网关仅对一种特定的应用程序执行这种检查。

显然，这为另一种设备提供了商机，即一种不仅能够检查所有通过它传递的分组的头部（类似于分组过滤器），而且能执行深度分组检查（与分组过滤器不同）的设备。当这

样的设备观察到一个可疑的分组时，或一系列可疑的分组时，它能够防止这些分组进入该机构网络。或者仅仅是因为觉得该活动可疑，该设备虽说能够让这些分组通过，但要向网络管理员发出告警，网络管理员然后密切关注该流量并采取适当的行动。当观察到潜在恶意流量时能产生告警的设备称为入侵检测系统（Intrusion Detection System, IDS）。滤除可疑流量的设备称为入侵防止系统（Intrusion Prevention System, IPS）。在本节中我们一起学习 IDS 和 IPS 这两种系统，因为这些系统的最为有趣的技术方面是它们检测可疑流量的原理（而不是它们是否发送告警或丢弃分组）。我们因此将 IDS 系统和 IPS 系统统称为 IDS 系统。

IDS 能够用于检测多种攻击，包括网络映射（例如使用 nmap 进行分析）、端口扫描、TCP 栈扫描、DoS 带宽洪泛攻击、蠕虫和病毒、操作系统脆弱性攻击和应用程序脆弱性攻击。（参见 1.6 节有关网络攻击的概述内容。）目前，数以千计的机构应用了 IDS 系统。这些已部署的系统有许多是专用的，Cisco、Check Point 和其他安全装备厂商在市场上销售这些系统。但是许多已部署的 IDS 系统是公共域系统，如极为流行的 Snort IDS 系统（我们将简要讨论它）。

一个机构可能在它的机构网络中部署一个或多个 IDS 传感器。图 8-36 显示了一个具有 3 个 IDS 传感器的机构。当部署了多个传感器时，它们通常共同工作，向一个中心 IDS 处理器发送有关可疑流量活动的信息，中心处理器收集并综合这些信息，当认为适合时向网络管理员发送告警。在图 8-36 中，该机构将其网络划分为两个区域：一个高度安全区域，由分组过滤器和应用程序网关保护，并且由 IDS 系统监视；一个较低度安全区域（称之为非军事区（DeMilitarized Zone, DMZ）），该区域仅由分组过滤器保护，但也由 IDS 系统监视。注意到 DMZ 包括了该机构需要与外部通信的服务器，如它的公共 Web 服务器和它的权威 DNS 服务器。

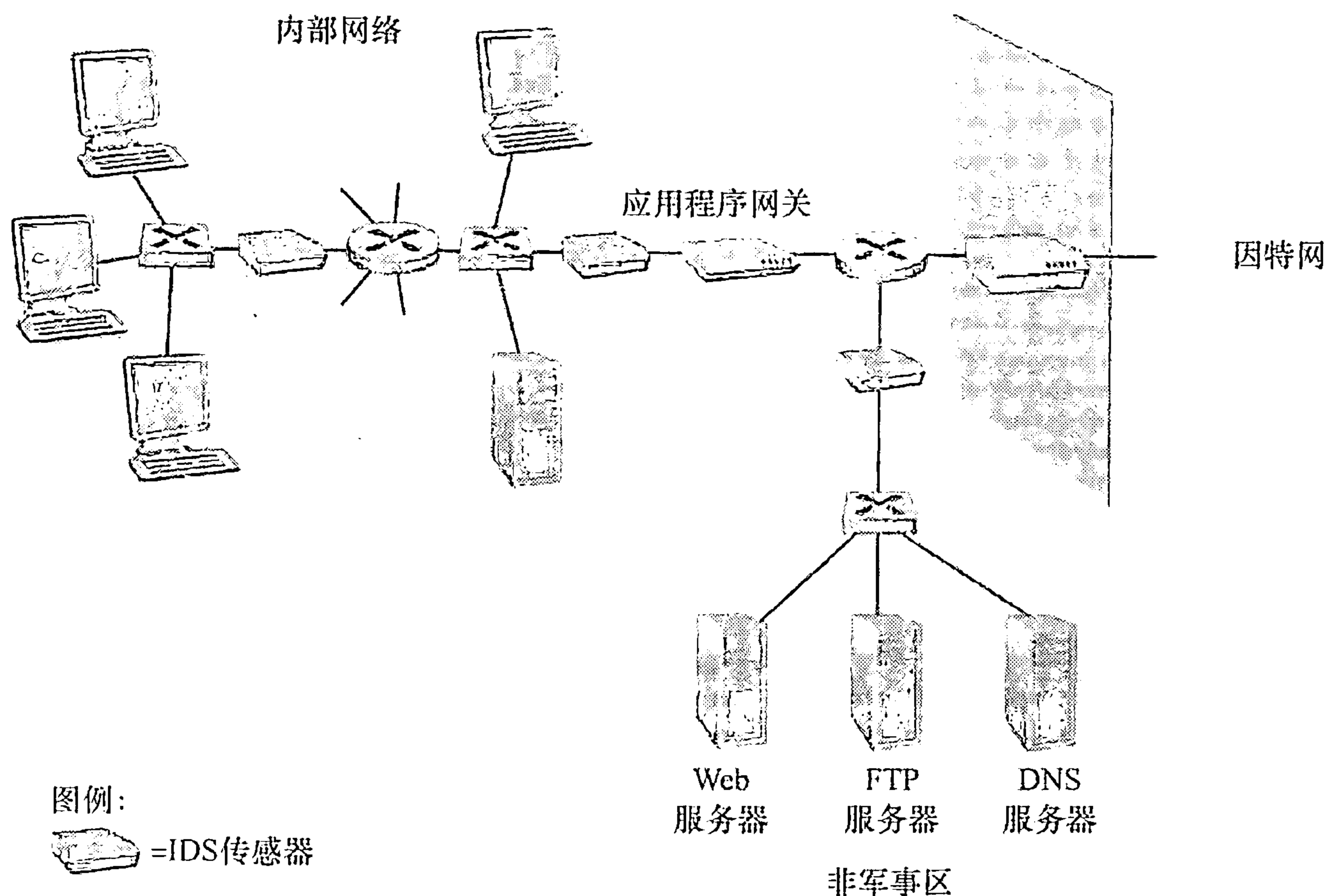


图 8-36 部署一个过滤器、一个应用程序网关和多个 IDS 传感器的机构

此时你也许想知道，为什么使用多个 IDS 传感器？为什么在图 8-36 中不只是在分组过滤器后面放置一个 IDS 传感器（或者甚至与分组过滤器综合）？我们将很快看到，IDS 不

仅需要做深度分组检查，而且必须要将每个过往的分组与数以万计的“特征（signature）”进行比较；这可能导致极大的处理量，特别是如果机构从因特网接收每秒数十亿比特的流量时更是如此。将 IDS 传感器进一步向下游放置，每个传感器仅看到该机构流量的一部分，维护能够更容易。无论如何，目前有许多高性能 IDS 和 IPS 系统可供使用，许多机构实际上能够在靠近其接入路由器附近只使用一个传感器。

IDS 系统大致可分类为基于特征的系统（signature-based system）或基于异常的系统（anomaly-based system）。基于特征的 IDS 维护了一个范围广泛的攻击特征数据库。每个特征是与一个入侵活动相关联的规则集。一个特征可能只是有关单个分组的特性列表（例如源和目的端口号、协议类型和在分组载荷中的特定比特串），或者可能与一系列分组有关。这些特征通常由研究了已知攻击、技艺熟练的网络安全工程师生成。一个机构的网络管理员能够定制这些特征或者将其加进数据库中。

从运行上讲，基于特征的 IDS 嗅探每个通过它的分组，将每个嗅探的分组与数据库中的特征进行比较。如果某分组（或分组序列）与数据库中的一个特征相匹配，IDS 产生一个告警。该告警能够发送一个电子邮件报文给网络管理员，能够发送给网络管理系统，或只是做日志以供以后检查。

尽管基于特征的 IDS 系统部署广泛，但仍具有一些限制。更重要的是，它们要求根据以前的攻击知识来产生一个准确的特征。换言之，基于特征的 IDS 对不得不记录的新攻击完全缺乏判断力。另一个缺点是，即使与一个特征匹配，它也可能不是一个攻击的结果，因此产生了一个虚假告警。最后，因为每个分组必须与范围广泛的特征集合相比较，IDS 可能处于处理过载状态并因此难以检测出许多恶意分组。

当基于异常的 IDS 观察正常运行的流量时，它会生成一个流量概况文件。然后，它寻找统计上不寻常的分组流，例如，ICMP 分组不寻常的百分比，或端口扫描和 ping 掠过导致指数性突然增长。基于异常的 IDS 系统最大的特点是它们不依赖现有攻击的以前知识。在另一方面，区分正常流量和统计异常流量是一个极具挑战性的问题。迄今为止，大多数部署的 IDS 主要是基于特征的，尽管某些 IDS 包括了某些基于异常的特性。

Snort

Snort 是一种公共域开放源码的 IDS，现有部署达几十万 [Snort 2012; Koziol 2003]。它能够运行在 Linux、UNIX 和 Windows 平台上。它使用了通用的嗅探接口 libpcap，Wireshark 和许多其他分组嗅探器也使用了 libpcap。它能够轻松地处理 100Mbps 的流量；安装在千兆比特/秒流量速率下工作，需要多个 Snort 传感器。

为了对 Snort 有一些认识，我们来看一个 Snort 特征的例子：

```
alert icmp $EXTERNAL_NET any -> $HOME_NET any
(msg:"ICMP PING NMAP"; dsize: 0; itype: 8;)
```

这个特征由从外部（\$EXTERNAL_NET）进入机构网络（\$HOME_NET）的任何 ICMP 分组所匹配，其类型是 8（ICMP ping）并且具有空负载（dsize = 0）。因为 nmap（参见 1.6 节）用这些特定的特征产生这些 ping 分组，所以设计出该特征来检测 nmap 的 ping 扫描。当某分组匹配该特征时，Snort 产生一个包括“ICMP PING NMAP”报文的告警。

也许关于 Snort 印象最为深刻的是巨大的用户社区和维护其特征数据库的安全专家。通常在一个新攻击出现后的几个小时内，Snort 社区就编写并发布一个攻击特征，然后它就能被分布在全世界的数十万 Snort 部署者下载。此外，使用 Snort 特征的语法，网络管理员能够根

据他们自己的机构需求，通过修改现有的特征或通过创建全新的特征来裁剪某个特征。

8.10 小结

在本章中，我们考察了秘密情人 Bob 和 Alice 能够用于安全通信的各种机制。我们看到 Bob 和 Alice 对下列因素感兴趣：机密性（因此只有他们才能理解传输的报文内容）、端点鉴别（因此他们确信正在与对方交谈）和报文完整性（因此他们确信在传输过程中他们的报文未被篡改）。当然，安全通信的需求并不限于秘密情人。的确，我们在 8.5 ~ 8.8 节中看到，可以在网络体系结构中的各个层次使用安全性，使之免受采用各种各样攻击手段的“坏家伙”的侵扰。

本章前面部分给出了安全通信所依赖的各种原理。在 8.2 节中，我们涉及了加密和解密数据的密码技术，包括对称密钥密码和公开密钥密码。作为今天网络中两种重要的密码技术的特定的学习案例，我们考察了 DES 和 RSA。

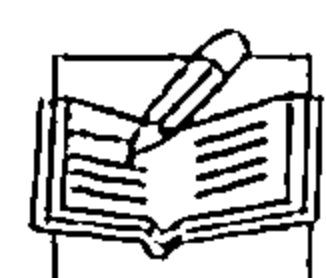
在 8.3 节中，我们研究了提供报文完整性的两种方法：报文鉴别码（MAC）和数字签名。这两种方法有一些共同之处。它们都使用了密码散列函数，这两种技术都使我们能够验证报文的源以及报文自身的完整性。一个重要的差异是 MAC 不依赖于加密，而数字签名要求公钥基础设施。如我们在 8.5 ~ 8.8 节所见，这两种技术广泛在实际中都得到了广泛应用。此外，数字签名用于生成数字证书，数字证书对于证实公钥的合法性是重要的。在 8.4 节中，我们考察了端点鉴别并引入了不重数以防御重放攻击。

在 8.5 ~ 8.8 节中，我们研究了几种在实践中得到广泛使用的安全性网络协议。我们看到了对称密钥密码在 PGP、SSL、IPsec 和无线安全性中的核心地位。我们看到了公开密钥密码对 PGP 和 SSL 是至关重要的。我们看到 PGP 使用数字签名而 SSL 和 IPsec 使用 MAC 来保证报文完整性。在目前理解了密码学的基本原理以及学习了这些原理的实际应用方法之后，你现在已经有能力设计你自己的安全网络协议了！

利用 8.2 ~ 8.4 节所包含的技术，Bob 和 Alice 就能够安全通信了。（只希望他们是学习了这些材料的网络专业学生，因此能够使他们的约会不会被 Trudy 发现！）而机密性仅是整个网络安全的一小部分。如我们在 8.9 节中所学习，现在网络安全的焦点越来越多地关注网络基础设施的安全性，以防止“坏家伙”的潜在猛烈攻击。在本章的后面部分，我们因此学习了防火墙和 IDS 系统，它们检查进入和离开一个机构网络的分组。

本章已经涉及了许多基础性问题，同时关注了现代网络安全性中最为重要的主题。希望深入钻研的读者最好研究本章中引用的文献。特别是，我们推荐以下读物：关于攻击和运行安全性的 [Skoudis 2006]，关于密码学及其如何应用于网络安全的 [Kaufman 1995]，关于 SSL 处理的有深度且可读性强的 [Rescorla 2001]，以及透彻地讨论 802.11 安全性的 [Edney 2003]（其中包括对 WEP 及其缺陷的深入研究）。

课后习题和问题



复习题

8.1 节

R1. 报文机密性和报文完整性之间的区别是什么？你能具有机密性而没有完整性吗？你能具有完整性而

没有机密性吗？证实你的答案。

R2. 因特网实体（路由器、交换机、DNS 服务器、Web 服务器、用户端系统等）经常需要安全通信。给出三个特定的因特网实体对的例子，它们要安全通信。

8.2 节

R3. 从服务的角度，对称密钥系统和公开密钥系统之间一个重要的差异是什么？

R4. 假定某入侵者拥有一个加密报文以及该报文的解密版本。这个入侵者能够发起已知密文攻击、已知明文攻击和选择明文攻击吗？

R5. 考虑一个 8 块密码。这个密码有多少种可能的输入块？有多少种可能的映射？如果我们将每种映射视为一个密钥，则该密码具有多少种可能的密钥？

R6. 假定 N 个人中的每个人都和其他 $N-1$ 个人使用对称密钥密码通信。任两人 (i 和 j) 之间的所有通信对该 N 个人的组中的所有其他人都是可见的，且该组中的其他人都不应当能够解密他们的通信。则这个系统总共需要多少个密钥？现在假定使用公开密钥密码。此时需要多少个密钥？

R7. 假定 $n = 10\,000$ 、 $a = 10\,023$ 和 $b = 10\,004$ 。请你使用等同的模算术来心算 $(a \cdot b) \bmod n$ 。

R8. 假设你要通过加密对应于报文 1010111 的十进制数来加密该报文。该十进制数是什么？

8.3 ~8.4 节

R9. 散列以何种方式提供比检验和（如因特网检验和）更好的报文完整性检验？

R10. 你能够“解密”某报文的散列来得到初始报文吗？解释你的答案。

R11. 考虑 MAC 算法（图 8-9）的一种变形算法，其中发送方发送 $(m, H(m) + s)$ ，这里 $H(m) + s$ 是 $H(m)$ 和 s 的级联。该变形算法有缺陷吗？为什么？

R12. 一个签名的文档是可鉴别的和不可伪造的，其含义是什么？

R13. 公钥加密的报文散列以何种方式比使用公钥加密报文提供更好的数字签名？

R14. 假设 certifier.com 生成一个用于 foo.com 的证书。通常整个证书将用 certifier.com 的公钥加密。这种说法是正确还是错误？

R15. 假设 Alice 有一个准备发送给任何请求者的报文。数以千计的人要获得 Alice 的报文，但每个人都要确保该报文的完整性。在这种场景下，你认为是基于 MAC 还是基于数字签名的完整性方案更为适合？为什么？

R16. 在某端点鉴别协议中，使用不重数的目的是什么？

R17. 我们说一个不重数是一个在生存期中只使用一次的值，这意味着什么？其中是指谁的生存期？

R18. 基于 HMAC 的报文完整性方案易受重放攻击影响吗？如果是，能够在方案中综合一个不重数来去除这种脆弱性吗？

8.5 ~8.8 节

R19. 假定 Bob 从 Alice 处接收一个 PGP 报文。Bob 怎样才能确定 Alice（而不是如 Trudy）生成了该报文？PGP 为保证报文完整性使用了 MAC 吗？

R20. 在 SSL 记录中，有一个字段用于 SSL 序号。这种说法是正确还是错误？

R21. 在 SSL 握手中随机不重数的目的是什么？

R22. 假设某 SSL 会话应用了具有 CBC 的块密码。服务器以明文向客户发送了 IV。这种说法是正确还是错误？

R23. 假设 Bob 向 Trudy 发起一条 TCP 连接，而 Trudy 正在伪装她是 Alice。在握手期间，Trudy 向 Bob 发送 Alice 的证书。在 SSL 握手算法的哪一步，Bob 将发现他没有与 Alice 通信？

R24. 考虑使用 IPsec 从主机 A 向主机 B 发送分组流。通常，为该流中的每个发送分组将创建一个新 SA。这种说法是正确还是错误？

R25. 假设在图 8-28 中总部和分支机构之间通过 IPsec 运行 TCP。如果 TCP 重新传输相同的分组，则由 R1 发送的两个对应的分组将在 ESP 首部中具有相同的序号。这种说法是正确还是错误？

R26. IKE SA 和 IPsec SA 是相同的東西。這種說法是正確還是錯誤？

R27. 考慮 802.11 的 WEP。假定數據是 10101100 並且密鑰流是 11110000。相應的密文是什麼？

R28. 在 WEP 中，在每個幀中以明文發送 IV。這種說法是正確還是錯誤？

8.9 節

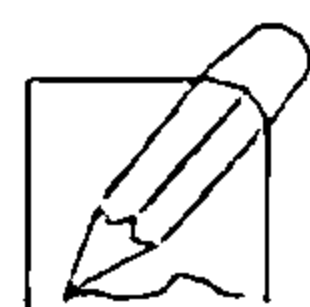
R29. 狀態分組過濾器維護兩個數據結構。給出它們的名字並簡單地討論它們做些什麼。

R30. 考慮某傳統的（無狀態的）分組過濾器。該分組過濾器可能基於 TCP 標誌位以及其他首部字段過濾分組。這種說法是正確還是錯誤？

R31. 在傳統的分組過濾器中，每個接口能夠具有自己的訪問控制表。這種說法是正確還是錯誤？

R32. 為什麼應用程序網關必須與分組過濾器協同工作才能有效？

R33. 基於特徵的 IDS 和 IPS 檢查 TCP 和 UDP 報文段的載荷。這種說法是正確還是錯誤？



習題

P1. 使用圖 8-3 中的單碼代替密碼，加密報文 “This is an easy problem”，並解密報文 “rnij'u uamu xyj”。

P2. Trudy 使用了已知明文攻擊，其中她知道了 7 個字母的（密文，明文）轉換對，減少了 8.2.1 節的例子中將被檢查的大約 10^9 數量級的可能替換的數量。請說明之。

P3. 考慮圖 8-4 所示的多碼代替密碼系統。利用報文 “The quick brown fox jumps over the lazy dogs” 得到的明文編碼，選擇明文攻擊足以破解所有報文嗎？為什麼？

P4. 考慮圖 8-5 中顯示的塊密碼。假設每個塊密碼 T_i 只是反轉了 8 個輸入比特的次序（例如，使得 11110000 變為 00001111）。進一步假設 64 比特置亂函數不修改任何比特（使得第 m 個比特的輸出值等於第 m 個比特的輸入值）。

a. 對於 $n=3$ 和初始 64 比特輸入等於 10100000 重複了 8 次，輸出的值是多少？

b. 重複（a），但此時將初始 64 比特的最後一個比特從 0 變為 1。

c. 重複（a）和（b），但此時假定 64 比特的置亂函數反轉了 64 比特的次序。

P5. 考慮圖 8-5 中的塊密碼。對於給定的“密鑰”，Alice 和 Bob 將需要 8 個表，每張表 8 比特乘以 8 比特。對於 Alice（或 Bob）來說，要存儲所有 8 張表，將需要多少比特的存儲器？這個數如何與一個全表 64 比特的塊密碼所需的比特數進行比較？

P6. 考慮在表 8-1 中的 3 比特塊密碼。假定明文是 100100100。

a. 初始假設未使用 CBC。生成的密文是什麼？

b. 假設 Trudy 嗅探該密文。假設她知道正在應用無 CBC 的一個 3 比特塊密碼（但不知道特定的密碼），她能夠推測到什麼？

c. 現在假設使用 CBC，其中 $IV=111$ 。產生的密文是什麼？

P7. 如題：

a. 使用 RSA，選擇 $p=3$ 和 $q=11$ ，採用對每個字母獨立地加密的方法加密短語 “dog”。對已加密報文應用解密算法恢復出原報文。

b. 重複（a），而此時加密 “dog” 作為一個報文 m 。

P8. 考慮具有 $p=5$ 和 $q=11$ 的 RSA。

a. n 和 z 是什麼？

b. 令 e 為 3。為什麼這是一個對 e 的可接受的選擇？

c. 求 d 使得 $de=1 \pmod{z}$ 和 $d<160$ 。

d. 使用密鑰 (n, e) 加密報文 $m=8$ 。令 c 表示對應的密文。顯示所有工作。提示：為了簡化計算，使用如下事實。

$$[(a \bmod n) \cdot (b \bmod n)] \bmod n = (a \cdot b) \bmod n$$

P9. 在這個習題中，我們探討 Diffie-Hellman (DH) 公鑰加密算法，該算法允許兩個實體協商一個共享的

密钥。该 DH 算法利用一个大素数 p 和另一个小于 p 的大数 g 。 p 和 g 都是公开的（因此攻击者将知道它们）。在 DH 中，Alice 和 Bob 每人分别独立地选择秘密密钥 S_A 和 S_B 。Alice 则通过将 g 提高到 S_A 并以 p 为模来计算她的公钥 T_A 。类似地，Bob 则通过将 g 提高到 S_B 并以 p 为模来计算他的公钥 T_B 。此后 Alice 和 Bob 经过因特网交换他们的公钥。Alice 则通过将 T_B 提高到 S_A 并以 p 为模来计算出共享密钥 S 。类似地，Bob 则通过将 T_A 提高到 S_B 并以 p 为模来计算出共享密钥 S' 。

- 证明在一般情况下，Alice 和 Bob 得到相同的对称密钥，即证明 $S = S'$ 。
- 对于 $p = 11$ 和 $g = 2$ ，假定 Alice 和 Bob 分别选择私钥 $S_A = 5$ 和 $S_B = 12$ ，计算 Alice 和 Bob 的公钥 T_A 和 T_B 。显示所有计算过程。
- 接着（b），现在计算共享对称密钥 S 。显示所有计算过程。
- 提供一个时序图，显示 Diffie-Hellman 是如何能够受到中间人攻击的。该时序图应当具有 3 条垂直线，分别对应 Alice、Bob 和攻击者 Trudy。

P10. 假定 Alice 要与采用对称密钥密码体制的 Bob 使用一个会话密钥 K_s 通信。在 8.2 节中，我们知道了如何使用公开密钥密码从 Alice 向 Bob 分发该会话密钥。在本习题中，我们探讨不使用公开密钥密码而使用一个密钥分发中心（KDC）分发会话密钥的方法。KDC 是一个与每个注册用户共享独特的秘密对称密钥的服务器。对于 Alice 和 Bob 而言， K_{A-KDC} 和 K_{B-KDC} 表示了这些密钥。设计一个使用 KDC 向 Alice 和 Bob 分发 K_s 的方案。你的方案应当使用三种报文来分发会话密钥：一种从 Alice 到 KDC 的报文；一种从 KDC 到 Alice 的报文；最后一种是从 Alice 到 Bob 的报文。第一种报文为 $K_{A-KDC}(A, B)$ 。使用标记 K_{A-KDC} 、 K_{B-KDC} 、 S 、 A 和 B 回答下列问题。

- 第二种报文是什么？
- 第三种报文是什么？

P11. 计算一个不同于图 8-8 中的两个报文的第三个报文，使该报文具有与图 8-8 中的报文相同的检验和。

P12. 假定 Alice 和 Bob 共享两个秘密密钥：一个鉴别密钥 S_1 和一个对称加密密钥 S_2 。扩充图 8-9，使之提供完整性和机密性。

P13. 在 BitTorrent P2P 文件分发协议中（参见第 2 章），种子将文件分割为块，并且对等方彼此重分发这些块。不使用任何保护，一个攻击者能够容易地通过假冒善意的对等方并向洪流中的一部分对等方发送假冒块来实施破坏。这些未被怀疑的对等方则重新向其他对等方发送这些假冒块，其他对等方则将再次向甚至更多的对等方重新分发这些假冒块。因此，对于 BitTorrent 来说，采用一种机制使对等方能验证一个块的完整性，从而使得假冒块无法分发，这是至关重要的。假设当某对等方加入一个洪流时，它初始从一个完全受信任的源得到一个 .torrent 文件。描述允许对等方验证块完整性的一个简单的方案。

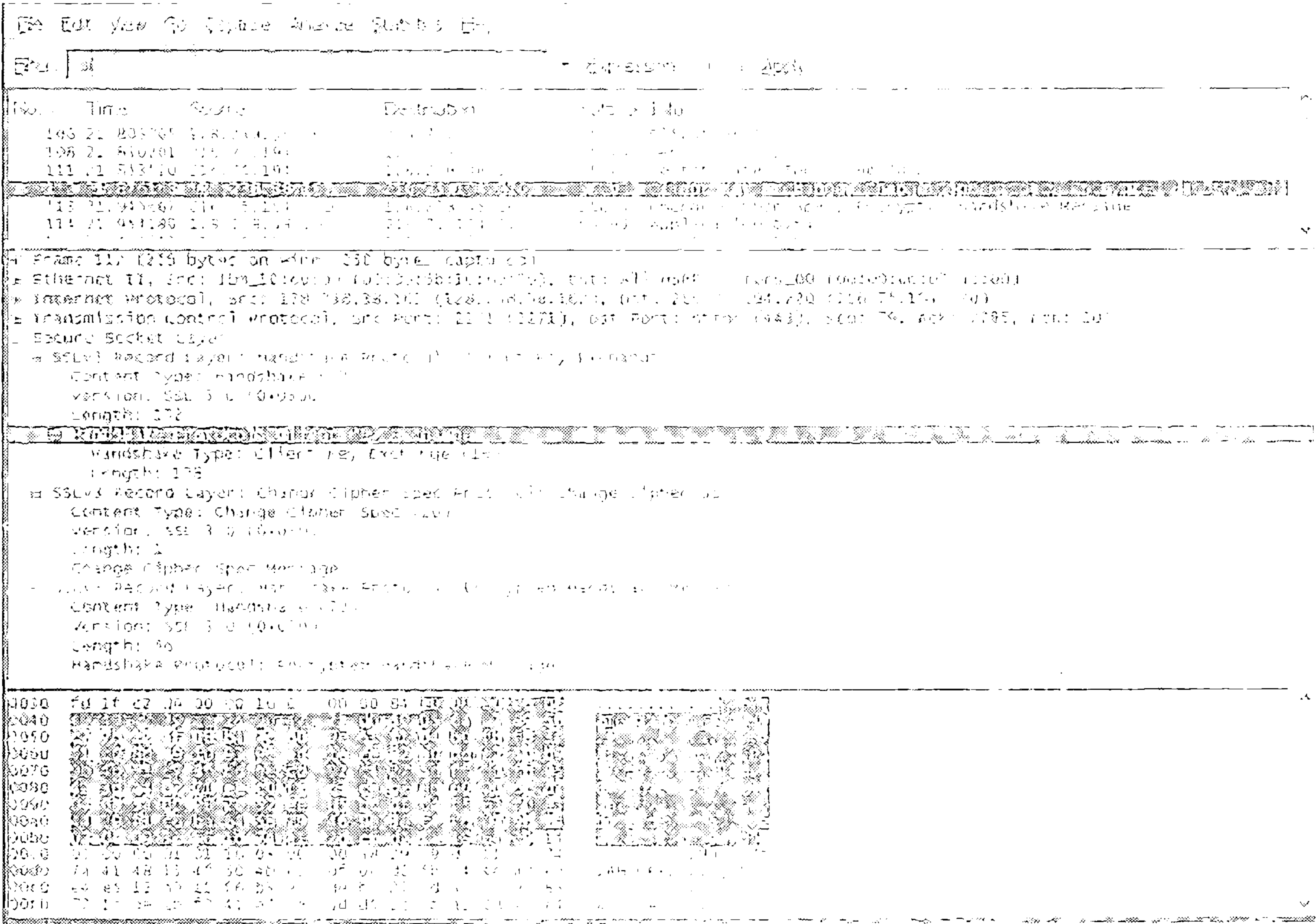
P14. OSPF 路由选择协议使用一个 MAC 而不是数字签名来提供报文完整性。你认为选择 MAC 而未选择数字签名的原因是什么？

P15. 考虑图 8-18 中的鉴别协议，其中 Alice 向 Bob 鉴别她自己，我们看来工作正常（即我们没有发现其中有缺陷）。现在假定当 Alice 向 Bob 鉴别她自己的同时，Bob 必须向 Alice 鉴别他自己。给出一个情况，此时 Trudy 假装是 Alice，向 Bob 鉴别她自己是 Alice。（提示：该协议运行的顺序，鉴别过程可由 Trudy 或 Bob 发起，能够任意地交织在一起。特别注意 Bob 和 Alice 将使用不重数这样一个事实，如果不小心的话，能够恶意地使用相同的不重数。）

P16. 一个自然的问题是我们能否使用一个不重数的公钥密码来解决 8.4 节中的端点鉴别问题。考虑下列自然的协议：① Alice 向 Bob 发送报文 “I am Alice”；② Bob 选择一个不重数并将其发送给 Alice；③ Alice 使用她的私钥来加密该不重数并向 Bob 发送得到的值；④ Bob 对接收到的报文应用 Alice 的公钥。因此，Bob 计算 R 并鉴别了 Alice。

- 画图表示这个协议，使用本书中应用的公钥和私钥的标记法。
- 假定未使用证书。描述 Trudy 怎样能够通过拦截 Alice 的报文，进而对 Bob 假装她是 Alice 而成为一名“中间人”。

- P17. 图 8-19 显示了 Alice 必须执行 PGP 的操作，以提供机密性、鉴别和完整性。图示出当 Bob 接收来自 Alice 的包时必须执行的对应操作。
- P18. 假定 Alice 要向 Bob 发送电子邮件。Bob 具有一个公共 - 私有密钥对 (K_B^+ , K_B^-)，并且 Alice 具有 Bob 的证书。但 Alice 不具有公钥私钥对。Alice 和 Bob（以及全世界）共享相同的散列函数 $H(\cdot)$ 。
- a. 在这种情况下，能设计一种方案使得 Bob 能够验证 Alice 创建的报文吗？如果能，用方框图显示 Alice 和 Bob 是如何做的。
 - b. 能设计一个对从 Alice 向 Bob 发送的报文提供机密性的方案吗？如果能，用方块图显示 Alice 和 Bob 是如何做的。
- P19. 考虑下面对于某 SSL 会话的一部分的 Wireshark 输出。
- a. Wireshark 分组 112 是由客户还是由服务器发送的？
 - b. 服务器的 IP 地址和端口号是什么？
 - c. 假定没有丢包和重传，由客户发送的下一个 TCP 报文段的序号将是什么？
 - d. Wireshark 分组 112 包含了多少个 SSL 记录？
 - e. 分组 112 包含了一个主密钥或者一个加密的主密钥吗？或者两者都不是？
 - f. 假定握手类型字段是 1 字节并且每个长度字段是 3 字节，主密钥（或加密的主密钥）的第一个和最后一个字节的值是什么？
 - g. 客户加密的握手报文考虑了多少 SSL 记录？
 - h. 服务器加密的握手报文考虑了多少 SSL 记录？



(Wireshark 屏幕截图的重印获得 Wireshark 基金会的许可)

- P20. 8.6.1 节中表明，不使用序号，Trudy（一名中间人）能够在一个 SSL 会话中通过互换 TCP 报文段实施破坏。Trudy 能够通过删除一个 TCP 报文段做某种类似的事情吗？在该删除攻击中，她需要做什么才能成功？它将具有什么影响？
- P21. 假定 Alice 和 Bob 通过一个 SSL 会话通信。假定一个没有任何共享密钥的攻击者，在某分组流中插

入一个假冒的 TCP 报文段，该报文段具有正确的 TCP 检验和及序号（以及正确的 IP 地址和端口号）。在接收侧 SSL 将接受该假冒分组并传递载荷给接收应用程序吗？为什么？

P22. 下列是有关图 8-28 的判断题。

- 当在 172.16.1/24 中的主机向一台 Amazon.com 服务器发送一个数据报时，路由器 R1 将使用 IPsec 加密该数据报。
- 当在 172.16.1/24 中的主机向在 172.16.2/24 中的主机发送一个数据报时，路由器 R1 将改变该 IP 数据报的源和目的地址。
- 假定在 172.16.1/24 中的主机向在 172.16.2/24 中的 Web 服务器发起一个 TCP 连接。作为此次连接的一部分，由 R1 发送的所有数据报将在 IPv4 首部字段最左边具有协议号 50。
- 考虑从在 172.16.1/24 中的主机向在 172.16.2/24 中的主机发送一个 TCP 报文段。假定对该报文段的应答丢失了，因此 TCP 重新发送该报文段。因为 IPsec 使用序号，R1 将不重新发送该 TCP 报文段。

P23. 考虑图 8-28 中的例子。假定 Trudy 是中间人，她能够在从 R1 和 R2 发出的数据报流中插入数据报。作为重放攻击一部分，Trudy 发送一个从 R1 到 R2 发送的数据报的冗余副本。R2 将解密该冗余的数据报并将其转发进分支机构网络吗？如果不是，详细描述 R2 如何检测该冗余的数据报。

P24. 考虑下列伪 WEP 协议。其密钥是 4 比特，IV 是 2 比特。当产生密钥流时，IV 被附加到密钥的后面。假定共享的密钥是 1010。密钥流的 4 个可能输入如下：

101000: 0010101101010101001011010100100...

101001: 1010011011001010110100100101101...

101010: 0001101000111100010100101001111...

101011: 1111101010000000101010100010111...

假定所有报文都是 8 比特长。假定 ICV（完整性检查）是 4 比特长，并且通过用数据的后 4 比特异或数据的前 4 比特来计算。假定该伪 WEP 分组由 3 个字段组成：首先是 IV 字段，然后是报文字段，最后是 ICV 字段，这些字段中的某些被加密。

- 我们希望使用 $IV = 11$ 和 WEP 发送报文 $m = 10100000$ 。在这 3 个 WEP 字段中将有什么样的值？
- 说明当接收方解密该 WEP 分组时，它恢复报文和 ICV。
- 假定 Trudy 截获了一个 WEP 分组（并不必要使用 $IV = 11$ ）并要在向接收方转发前修改该分组。假定 Trudy 翻转了第一个 ICV 比特。假定 Trudy 并不知道用于任何 IV 的密钥流，则 Trudy 也必须翻转哪些其他比特，使得接收到的分组通过 ICV 检查？
- 通过修改（a）中 WEP 分组中的比特，解密所生成的分组，并验证完整性检查来评价你的答案。

P25. 对于尽可能限制但能实现下列功能的一台有状态防火墙，提供一张过滤器表和一张连接表：

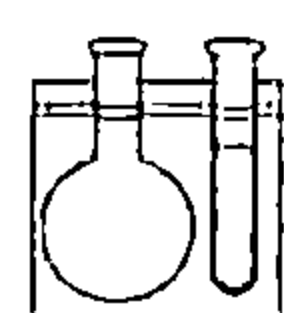
- 允许所有的内部用户与外部用户创建 Telnet 会话。
- 允许外部用户冲浪公司位于 222.22.0.12 的 Web 站点。
- 否则阻挡所有入流量和出流量。

内部网络为 222.22/16。在你的答案中，假设连接表当前缓存了 3 个从内向外的连接。你需要虚构适当的 IP 地址和端口号。

P26. 假设 Alice 要使用 TOR 类似的服务访问 Web 站点 activist.com。该服务使用两个不串通的代理服务器 Proxy1 和 Proxy2。Alice 首先从某个中央服务器获得对 Proxy1 和 Proxy2 的证书（每个都包含一个公钥）。用 K_1^+ 、 K_2^+ 、 K_1^- 和 K_2^- 表示加密/解密时所使用的 RSA 公钥和 RSA 私钥。

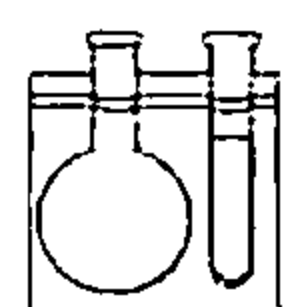
- 使用一幅时序图，提供一个（尽可能简单的）协议允许 Alice 创建一个用于 Proxy1 的共享会话密钥 S_1 。 $S_1(m)$ 表示为使用共享密钥 S_1 对数据 m 加密/解密。
- 使用时序图，提供一个（尽可能简单的）协议允许 Alice 创建一个对于 Proxy2 的共享会话密钥 S_2 ，而不向 Proxy2 透露她的 IP 地址。

- c. 现在假设创建了共享密钥 S_1 和 S_2 。使用时序图提供一个协议（尽可能简单并且不使用公开密钥密码），该协议允许 Alice 从 activist.com 请求一个 html 页面而不向 Proxy2 透露她的 IP 地址，并且不向 Proxy1 透露她正在访问哪个站点。你的图应当终止在一个 HTTP 请求到达 activist.com。



Wireshark 实验

在这个实验中（与本书配套的 Web 站点有可用资源），我们研究安全套接层（SSL）协议。8.6 节讲过，使用 SSL 使得 TCP 连接更为安全，为了使因特网事务安全，实践中广泛应用了 SSL。在本实验中我们关注经 TCP 连接发送的 SSL 记录。我们将试图对每个记录定界和分类，目标是理解每个记录的工作原理和工作过程。我们研究各种 SSL 记录类型以及在 SSL 报文中的字段。通过分析你的主机与某电子商务服务器之间发送的 SSL 记录的踪迹来做这些事情。



IPsec 实验

在这个实验中（与本书配套的 Web 站点有可用资源），我们将探讨如何在 linux 装置之间创建 IPsec SA。你能够用两个普通的 linux 装置做该实验的第一部分，每个装置配有一块以太网适配器。但是对于实验的第二部分，你将需要 4 个 linux 装置，这些装置每个都具有两块以太网适配器。在该实验的第二部分，你将在隧道模式中使用 ESP 协议创建 IPsec SA。你做实验过程是：先人工创建 SA，然后让 IKE 创建 SA。



人物专访

Steven M. Bellovin 在位于新泽西州 Florham Park 的 AT&T 实验研究所的网络服务研究实验室工作多年后，成为了哥伦比亚大学的教师。他的研究重点是网络和安全，以及将两者有机结合起来。1995 年，因创立了 Usenet，即第一个连接两个或多个计算机并允许用户共享信息和参与讨论的新闻组交换网络，而被授予 Usenix 终生成就奖。Steven 也是国家工程学会的当选成员。他获得了哥伦比亚大学的学士学位和位于 Chapel Hill 的北卡罗来纳大学的博士学位。



Steven M. Bellovin

- 什么原因使您决定专注于网络安全领域的研究？

听起来可能很奇怪，但是答案却很简单：只是因为感兴趣而已。我以前的背景是从事系统编程和系统管理，这很自然就发展到安全领域了。而且我一直对通信很感兴趣，这可以追溯到我还上大学时，就兼职做系统编程方面的工作。

我在安全领域的工作持续受到两个因素的激励：一个是希望计算机有用，这意味着它们的功能不会被攻击者破坏，另一个是希望保护隐私。

- 当初您在研发 Usenet 时，您对它的愿景是什么？现在呢？

我们最初将它看作是一种能够在全国范围内讨论计算机科学和计算机编程的手段，考虑了用于事务管理和广告销售等目的的许多本地使用情况。事实上，我最初的预测是，每天从至多 50 ~ 100 个站点有 1 ~ 2 个报文。但是实际增长是与人相关的主题方面，包括（但不限于）人与计算机的相互作用。这么多年来，我喜欢的新闻组有 rec. woodworking 以及 sci. crypt。

在某种程度上，网络新闻已经被 Web 取代。如果现在要我再设计它的话，就会和那时的设计大不相同了。但是它仍然是沟通对某一主题感兴趣的大量读者的一种极好手段，而不必依赖特定的 Web 站点。

- 是否有人给过您专业上的启示和灵感？以什么样的方式呢？

Fred Brooks 教授对我的专业生涯影响重大。他是位于 Chapel Hill 的北卡罗来纳大学计算机科学系的创立者和原系主任，是研发 IBM S/360 和 OS/360 团队的管理者。他也是 “The Mythical Man Mouth”

(《人月神话》)的作者。最重要的是,他教给我们展望和折中的方法,即如何在现实世界环境中观察问题(不论这个现实世界比理论上的要复杂多少倍),以及在设计一种解决方案时如何平衡竞争各方的利益。大部分计算机工作都是工程性的,正确折中的艺术能够满足许多相矛盾的目标。

- 您对未来的联网和安全性的展望是什么?

到目前为止,我们所具有的安全性大多来自隔离。例如,防火墙的工作是通过切断某些机器和服务实现的。但是我们正处在增加连通性的时代,这使得隔离变得更为困难。更糟糕的是,我们的生产性系统要求的远不止是分离的部件,而需要通过网络将它们互联起来。我们面临的最大挑战之一是使所有都安全。

- 您认为在安全性方面已经取得的最大进展是什么?未来我们还能有多大作为?

至少从科学上讲,我们知道了密码学的原理。这是非常有帮助的。但是多数安全性问题因为其代码错误成堆而成为非常困难的问题。事实上,它是计算机科学中悬而未决的老问题,并且我认为该问题仍会持续。挑战在于弄明白:当我们不得不使用不安全的组件构建安全的系统时,如何才能让系统安全。我们面对硬件故障已经能够解决可靠性问题了;面对安全性问题,我们是否能够做到这一点呢?

- 对于从事因特网和网络安全的学生们,您有何忠告?

学习各种安全机制是件容易的事。学习如何“思维多疑”是困难的。你必须记住概率分布在下列场合并不适用,即攻击者能够发现不可能的情况。细节情况不胜枚举。

网络管理

通过本书前8章内容的学习，我们现在已经得知网络是由许多复杂的、交互的硬件和软件实体组成的，它们包括链路、交换机、路由器、主机和其他由网络物理部件组成的设备，还包括控制和协调这些设备的许多协议（以硬件和软件形式出现）。当一个机构将数以百计或数以千计的这些部件拼装在一起成为一个网络时，出现如下一些现象将是不足为奇的：网络部件偶尔出现故障，网络元素配置错误，网络资源过度使用，或网络部件完全“崩溃”（例如，电缆被切断，或一听汽水翻倒在一台路由器上）。网络管理员的工作是保持该网络“启动和运行”，他们必须能够对这些问题做出反应，最好是避免它们的出现。由于成千上万的网络部件可能散布在广泛的区域中，在网络运营中心（NOC）的网络管理员显然需要工具来监视、管理和控制网络。在本章中，我们将探讨网络管理员在网络管理任务中所使用的体系结构、协议和信息库。

9.1 什么是网络管理

在深入研究网络管理之前，我们首先考虑一些“真实世界”的非网络环境中的几个说明性例子，即在一个复杂系统中，管理人员要对系统中交互的部件进行监测、管理和控制。发电厂具有控制室，其中有标度盘、测量仪和灯光，它们用来监视远程的阀门、管子、容器和其他工厂设备的状态（温度、压力、流量）。这些设备允许操作员监测该工厂的许多部件，并当故障到来时能向操作员告警（用周知的红色闪光警灯）。工厂操作员采取措施来控制这些部件。类似地，飞机驾驶室的安排将使飞行员能够监视和控制飞机的许多部件。在这两个例子中，“管理人员”监测远程设备并分析相关数据，以确保这些设备能够使用，并在所规定的限制中运行（例如，核电厂的核反应堆心不会很快熔化，或者飞机的燃料不会用完），根据系统中的变化或其环境进行调整，反应式地控制系统；以及主动式地管理系统（例如，通过检测趋势或异常行为，在出现严重问题之前采取行动）。与此类似，网络管理人员要主动监测、管理和控制他们所负责的系统。

在网络发展的初期，计算机网络还处于供研究的初级阶段，而不是数千万人每日必用的重要基础设施，“网络管理”还是一个闻所未闻的超前概念。如果一个人遇到了网络问题，他可能多次运行 ping 程序对该问题的源进行定位，接着修改系统设置，重新启动硬件或软件，或者打电话让远程的同事来做这些事情。（一个非常值得阅读的材料是 [RFC 789]：自 1980 年 10 月 27 日 ARPAnet 第一次严重“崩溃”后很久，都没有可供使用的网络管理工具，网络管理员努力工作以恢复崩溃的系统，并试图理解这次崩溃的原因）。随着公共因特网和专用内联网从小型网络成长成为巨大的全球基础设施，更为系统地管理这些网络中的大量硬件和软件组件的需求也就变得更为重要了。

为了激发读者学习网络管理的热情，我们的讨论将从一个简单的例子开始。图 9-1 显示了一个小型网络，该网络由 3 台路由器和若干台主机及服务器组成。即使在这样一个简单的网络中，在许多情况下网络管理员也从使用适当的网络管理工具中得到许多益处：

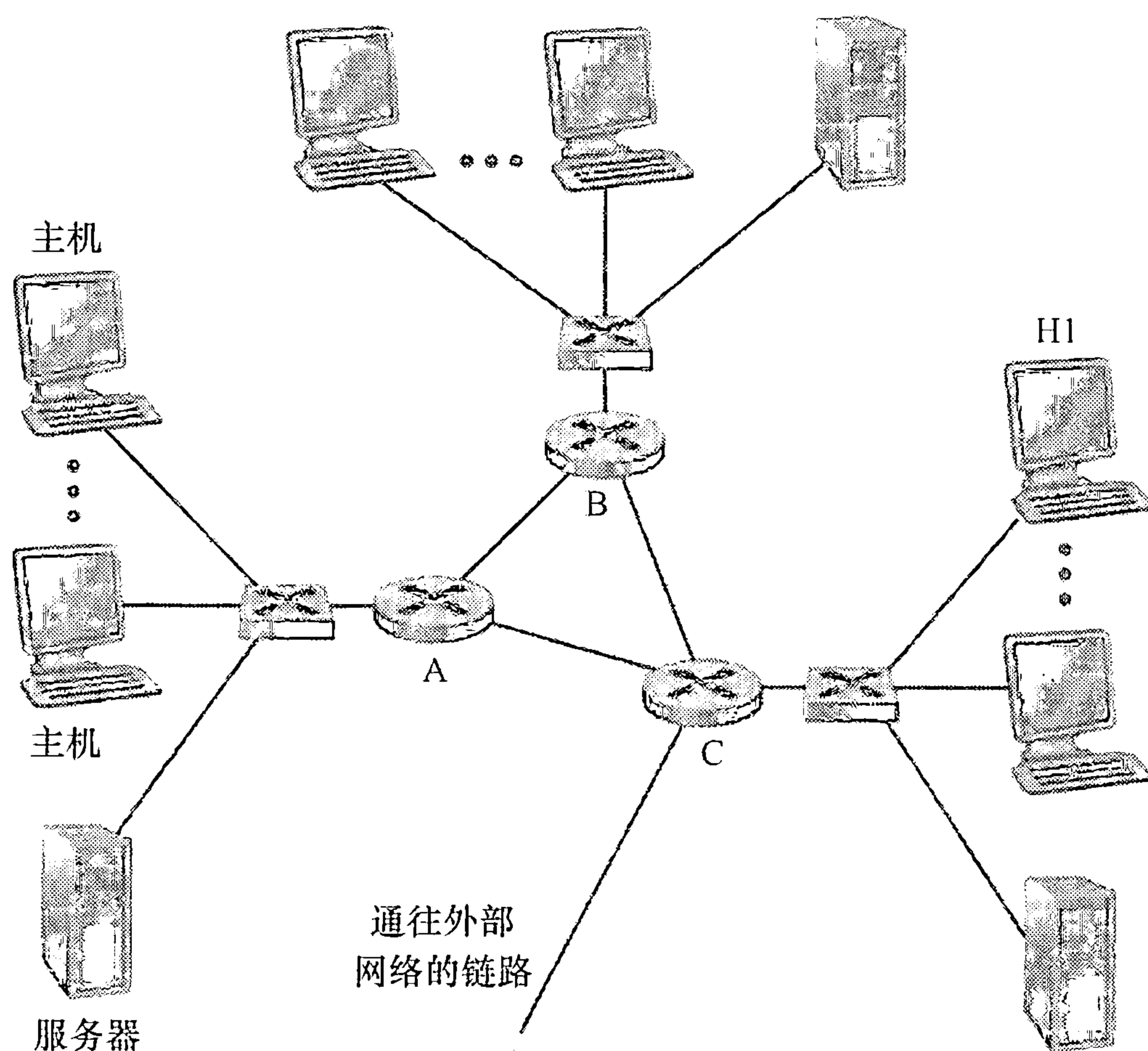


图 9-1 一个简单的说明网络管理用途的场景

- 检测主机或路由器接口卡的故障。利用适当的网络管理工具，一个网络实体（例如路由器 A）可以向网络管理员报告它的一个接口卡已经失效。（这无疑比一个发怒的用户打电话向网络运营中心（NOC）抱怨网络连接已经中断要好得多！）主动监测和分析网络流量的网络管理员可以通过事先检测到接口中存在问题，并在它发生故障之前换掉它，这样会给原来要发怒的用户留下非常深刻的印象。例如，如果该管理员注意到由这块即将失效的接口所发送的帧中的检验和差错增加，就可能发现接口卡存在的问题。
- 主机监测。在这种场合下，该网络管理员可以进行周期性地检查，看是否所有的网络主机开机和运行。同样，该网络管理员通过在用户报告之前提前对问题（如主机停机）做出响应，这也会给网络用户留下深刻的印象。
- 监测流量以帮助部署资源。例如，网络管理员可以通过监测源到目的地流量的模式并且通告在 LAN 网段间切换服务器，使得跨越多个 LAN 的流量大大减少。若不增加新设备成本而取得更好的网络性能，是件皆大欢喜的事情。类似地，通过监测链路利用率，网络管理员可能决定某条 LAN 网段或通往外部的链路将要过载，因此应当提供更高带宽的链路（当然要增加成本）。网络管理员也可能希望在出现链路拥塞等级超过给定阈值的情况下，自动得到通知，使得在拥塞变得严重之前，配备更大带宽的链路。
- 检测路由选择表中的快速变化。路由颤动（route flapping）即路由选择表内容的经常变化，可能表明路由选择的不稳定或路由器配置不正确。那些不正确地配置了路由器的网络管理员，无疑希望自己在该网络瘫痪之前发现这个错误。

- 服务等级协定的监测。服务等级协定 (Service Level Agreement, SLA) 是契约, 定义了特定的性能测度和网络提供商提供的相对于这些性能测度的可接受性能等级 [Huston 1999a]。Verizon 和 Sprint 是两个网络提供商, 它们与其他 ISP 一样向其用户提供确保的 SLA [AT&T SLA 2012; Verizon 2012]。这些 SLA 包括服务可用性 (断线率)、时延、吞吐量和断线通知要求。很显然, 如果性能标准是网络提供商和其用户间服务协定的一部分的话, 那么测量和管理性能对于网络管理员是十分重要的。
- 入侵检测。当网络流量来自一个可疑源或预定要流向一个可疑源 (例如, 主机或端口号) 时, 网络管理员可能希望得到提示。类似地, 网络管理员可能希望检测 (并在许多情况下过滤) 某类流量的存在 (例如, 源路由选择分组或指向给定主机的大量 SYN 分组), 这被认为具有安全性攻击类型的特征, 我们已在第 8 章中讨论过了。

国际标准化组织 (ISO) 已经建立了一个网络管理模型, 该模型对于将上述各种各样的情况放置于更为结构化的框架中是有用的。该模型定义了网络管理的 5 个领域:

- 性能管理 (performance management)。性能管理的目标是量化、测量、报告、分析和控制不同网络部件的性能 (如利用率和吞吐量)。这些部件包括各个设备 (如链路、路由器和主机) 以及如通过某网络的路径那样的端到端抽象。我们很快将会看到, 如简单网络管理协议 (Simple Network Management Protocol, SNMP) [RFC 3410] 这样的协议标准在因特网性能管理中起着最重要的作用。
- 故障管理 (fault management)。故障管理的目标是记录、检测和响应网络中的故障情况。故障管理和性能管理之间的区别是相当模糊的。我们能够认为故障管理是对暂时性网络故障 (例如, 链路、主机及路由器硬件或软件的停转) 的及时处理, 而性能管理采取更为长期的观点, 面对变化的流量要求和偶尔的网络设备故障, 提供可接受的性能等级。与性能管理一样, SNMP 协议在故障管理中起着最重要的作用。
- 配置管理 (configuration management)。配置管理允许网络管理员跟踪被管理网络中的那些设备, 跟踪这些设备的硬件和软件配置。有关基于 IP 网络的配置管理和要求的概述可参见 [RFC 3139]。
- 账户管理 (accounting management)。账户管理允许网络管理员定义、记录、控制用户和设备访问网络资源。限额使用、基于使用的收费和分配资源访问权限都属于账户管理的范围。
- 安全管理 (security management)。安全管理的目标是根据某些定义明确的策略控制对网络资源的访问。我们在 8.3 节中讨论的密钥分发中心是安全管理的一部分。使用防火墙监视和控制网络的外部接入点既是我们在 8.9 节中讨论的一个主题, 也是本章的一个重要部分。

在本章中, 我们仅将涉及网络管理的入门知识。我们有意识地关注有限的范围, 讨论网络管理的基础设施, 即总体体系结构、网络管理协议和信息库, 网络管理员将通过该信息库保持网络正常运行。我们将不涉及网络管理员的决策过程, 其中网络管理员必须对传送到 NOC 的网络信息进行规划、分析和做出响应。在这个领域中, 诸如故障标识和管理 [Katzela 1995; Medhi 1997; Labovitz 1997; Steinder 2002; Feamster 2005; Wu 2005; Teix-